การประมวลผลแบบกลุ่มเมฆ Cloud Computing

IT368

Lecture 8 – Cloud Security & Migration

Cloud Security Overview

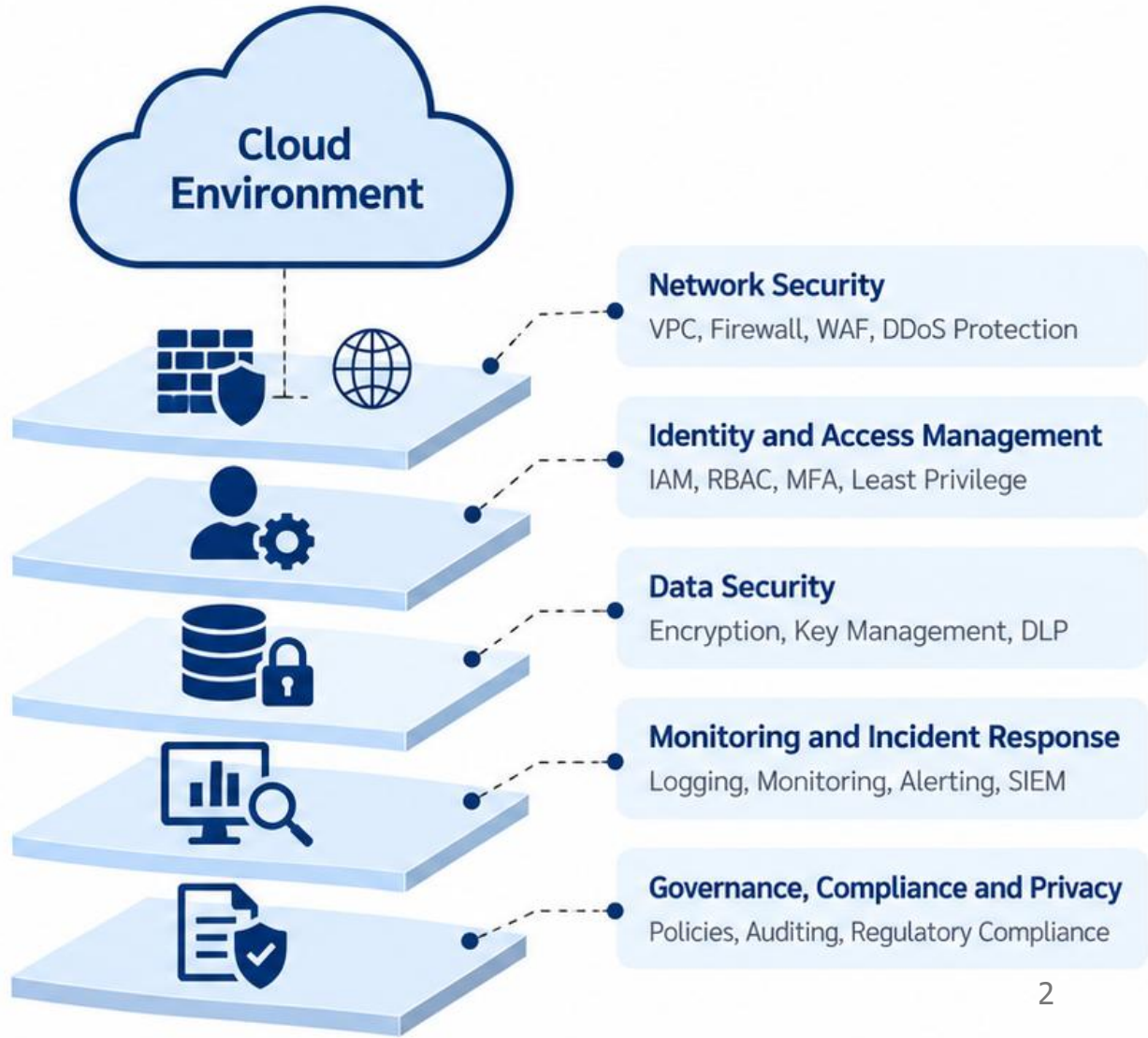
Cloud Security คือการปกป้องข้อมูล ระบบ และบริการบน Cloud จากภัยคุกคามต่าง ๆ
โดยใช้มาตรการด้านเทคโนโลยี กระบวนการ และการบริหารจัดการ

เป้าหมายของ Cloud Security

- รักษาความลับของข้อมูล (Confidentiality)
- รักษาความถูกต้องของข้อมูล (Integrity)
- รักษาความพร้อมใช้งานของระบบและบริการ (Availability)
- ลดความเสี่ยงและปฏิบัติตามข้อกำหนด (Compliance)

หลักการสำคัญ

- **Shared Responsibility**
  แบ่งความรับผิดชอบระหว่างผู้ให้บริการ Cloud และผู้ใช้งาน
- **Defense in Depth**
  ใช้มาตรการหลายชั้นเพื่อป้องกันความเสี่ยง
- **Least Privilege**
  ให้สิทธิ์เท่าที่จำเป็นเท่านั้น
- **Zero Trust**
  ไม่เชื่อถือโดยอัตโนมัติ ตรวจสอบทุกการเข้าถึง
- **Continuous Monitoring**
  ตรวจสอบและตอบสนองต่อเหตุการณ์อย่างต่อเนื่อง



Common Cloud Security Threats

แม้ Cloud Provider จะมีมาตรการรักษาความปลอดภัยที่แข็งแกร่ง แต่การตั้งค่าระบบ การจัดการสิทธิ์ และพฤติกรรมของผู้ใช้งานยังคงเป็นปัจจัยสำคัญที่ทำให้เกิดความเสี่ยงด้านความปลอดภัยบน Cloud

Misconfiguration
การตั้งค่าระบบ Cloud ไม่ปลอดภัย เช่น เปิด Storage ให้สาธารณะ หรือกำหนดสิทธิ์กว้างเกินไป

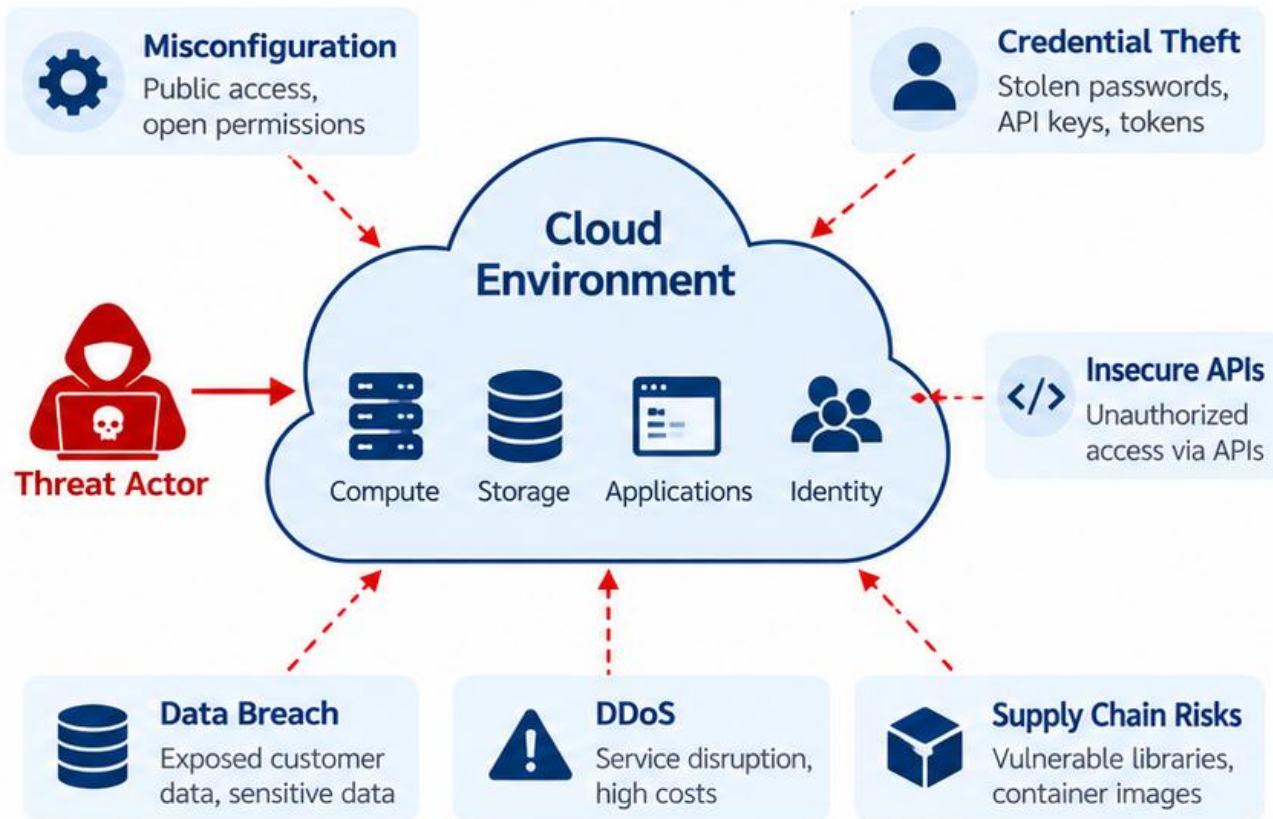
Credential Theft
ผู้โจมตีขโมยรหัสผ่าน API Key หรือ Access Token เพื่อเข้าถึงทรัพยากรบน Cloud

Insecure APIs
API ที่ไม่มีการยืนยันตัวตนหรือตรวจสอบสิทธิ์อย่างเหมาะสม อาจถูกใช้เข้าถึงข้อมูลโดยไม่ได้รับอนุญาต

Data Exposure / Data Breach
ข้อมูลสำคัญ เช่น ข้อมูลลูกค้า หรือข้อมูลธุรกิจ ถูกเปิดเผยจากการตั้งค่าผิดพลาดหรือการเข้าถึงโดยไม่ได้รับอนุญาต

Denial of Service (DDoS)
การโจมตีเพื่อทำให้ระบบไม่สามารถให้บริการได้ หรือใช้งานทรัพยากรจนเกิดค่าใช้จ่ายสูงจำนวนมาก

Supply Chain Risks
ความเสี่ยงจาก Third-party Libraries, Container Images, CI/CD Pipelines และ Software Dependencies



Shared Responsibility Model

การรักษาความปลอดภัยบน Cloud เป็นความรับผิดชอบร่วมกันระหว่าง Cloud Provider และลูกค้า
โดยขอบเขตความรับผิดชอบจะแตกต่างกันตามรูปแบบบริการ (IaaS, PaaS, SaaS)

Layer / Responsibility	IaaS (Customer / Provider)	PaaS (Customer / Provider)	SaaS (Customer / Provider)
Physical Data Center	Provider	Provider	Provider
Physical Infrastructure	Provider	Provider	Provider
Hypervisor / Virtualization	Provider	Provider	Provider
Operating System	Customer	Provider	Provider
Runtime and Middleware	Customer	Provider	Provider
Application Code	Customer	Customer	Provider
Data	Customer	Customer	Customer
User Access and Identity	Customer	Customer	Customer
Security Configuration	Customer	Customer	Customer
Compliance and Governance	Customer	Customer	Customer

Provider Responsibility
(ความรับผิดชอบของผู้ให้บริการ Cloud)

Customer Responsibility
(ความรับผิดชอบของลูกค้า / ผู้ใช้งาน)

Cloud Service Models

Infrastructure as a Service (IaaS)

- ลูกค้าดูแล OS, Middleware, Application และ Data เอง
- เหมาะกับองค์กรที่ต้องการความยืดหยุ่นในการควบคุมระบบ

Platform as a Service (PaaS)

- ผู้ให้บริการดูแล OS และ Runtime
- ลูกค้าดูแล Application และ Data
- เหมาะกับการพัฒนาและDeploy Application ได้รวดเร็ว

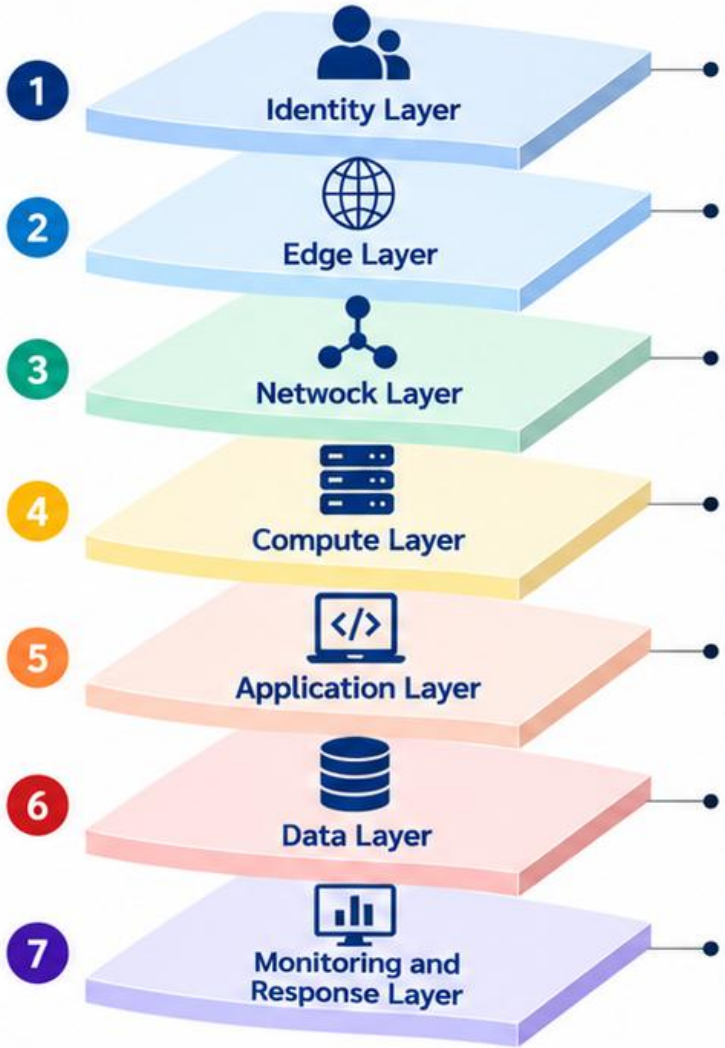
Software as a Service (SaaS)

- ผู้ให้บริการดูแล Applicatiore ทั้งหมด
- ลูกค้าดูแลการกำหนดสิทธิ์และการใช้งานข้อมูล
- เหมาะสำหรับการใช้งานซอฟต์แวร์สำเร็จรูป เช่น Email, CRM, Collaboration Tools

แม้ผู้ให้บริการจะดูแล Infrastructure และ Platform แต่ลูกค้ายังคงรับผิดชอบต่อการรักษาความปลอดภัยของข้อมูล การกำหนดสิทธิ์ และการตั้งค่าระบบบน Cloud

Defense in Depth

การออกแบบความปลอดภัยแบบหลายชั้น (Defense in Depth) เพื่อป้องกัน ลดความเสี่ยง และจำกัดความเสียหาย หากการควบคุมในชั้นใดชั้นหนึ่งถูกเจาะผ่าน



ป้องกันการเข้าถึงโดยไม่ได้รับอนุญาต
เช่น IAM, MFA, RBAC, Least Privilege, Conditional Access

ป้องกันภัยคุกคามจากภายนอก
เช่น DDoS Protection, Web Application Firewall (WAF), Load Balancer

ควบคุมการสื่อสารระหว่างระบบ
เช่น VPC, Subnet, Firewall, Network ACL, Private Endpoint

ปกป้องเซิร์ฟเวอร์และเวิร์กโหลด
เช่น OS Hardening, Patch Management, Vulnerability Scanning

ป้องกันช่องโหว่ของแอปพลิเคชัน
เช่น Secure Coding, Input Validation, API Security, Runtime Protection

ปกป้องข้อมูลตลอดวงจรชีวิต
เช่น Encryption, Key Management, Data Classification, Backup

ตรวจจับ ตอบสนอง และกู้คืนเหตุการณ์
เช่น Logging, Monitoring, SIEM, Incident Response, Disaster Recovery

Key Takeaways

- ไม่มีมาตรการใดเพียงอย่างเดียวที่สามารถป้องกันทุกภัยคุกคามได้
- หากชั้นหนึ่งถูกเจาะผ่าน ชั้นถัดไปจะช่วยลดความเสียหาย
- ควรใช้ทั้ง Preventive, Detective และ Corrective Controls
- ต้องออกแบบให้ครอบคลุมทั้ง People, Process และ Technology

ประโยชน์ของ Defense in Depth

- ลดความเสี่ยงจากการโจมตีที่หลากหลาย
- จำกัดผลกระทบและลดความเสียหาย
- เพิ่มโอกาสในการตรวจจับเหตุการณ์
- ช่วยให้องค์กรปฏิบัติตามข้อกำหนดด้านความปลอดภัยและกฎหมาย

IAM

Identity and Access Management (IAM)

IAM คือกระบวนการและบริการที่ใช้จัดการตัวตนผู้ใช้ (Identity) การยืนยันตัวตน (Authentication) และกำหนดสิทธิ์การเข้าถึง (Authorization) ทรัพยากรบน Cloud

องค์ประกอบของ IAM

Identity
ตัวตนของผู้ใช้หรือระบบ
(User, Group, Service Account)

Authentication
การยืนยันตัวตน
(เช่น Password, MFA, SSO)

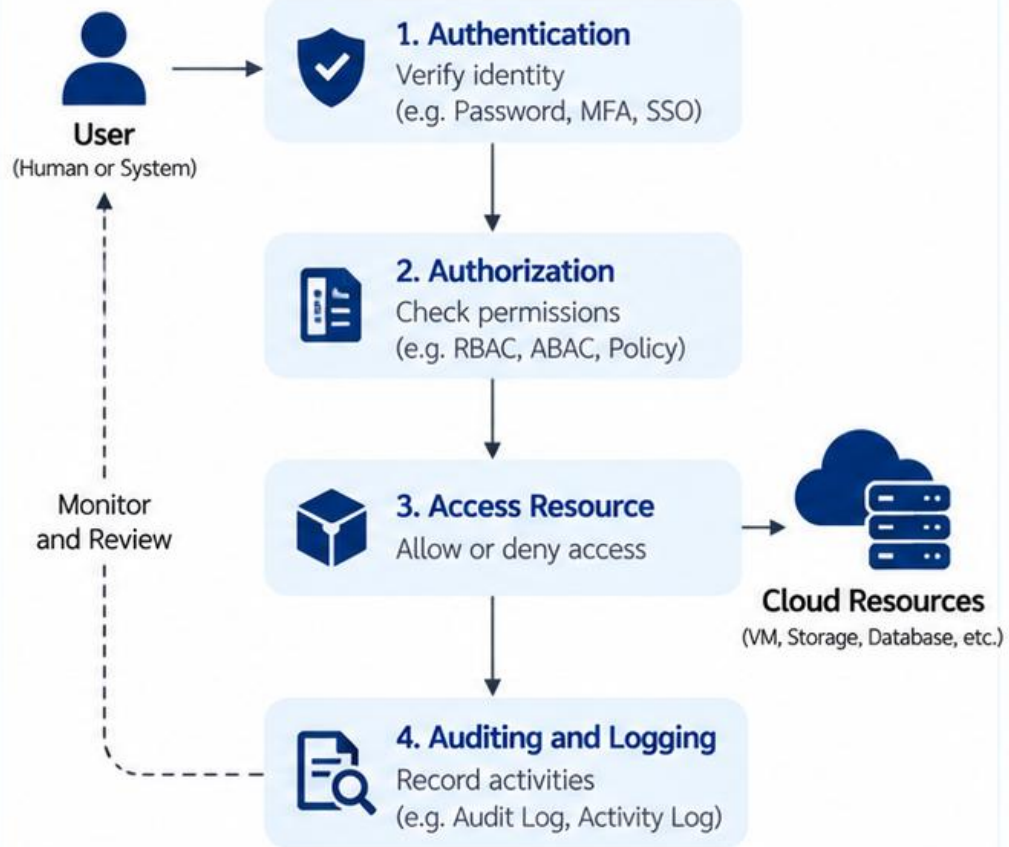
Authorization
การกำหนดสิทธิ์การเข้าถึง
(เช่น RBAC, ABAC, Policy)

Permission
สิทธิ์ที่อนุญาตให้ดำเนินการ
(เช่น Read, Write, Delete)

Resource
ทรัพยากรบน Cloud
(เช่น VM, Storage, Database)

Auditing
ตรวจสอบและบันทึกกิจกรรม
(Audit Log, Activity Log)

How IAM Works



Authentication Methods

- Username and Password
- Multi-Factor Authentication (MFA)
- Single Sign-On (SSO) and Federation
- Passkeys and Modern Authentication

Key Principles

Least Privilege
ให้สิทธิ์เท่าที่จำเป็นเท่านั้น

Separation of Duties
แยกหน้าที่สำคัญเพื่อลดความเสี่ยง

Regular Access Review
ตรวจสอบและทบทวนสิทธิ์อย่างสม่ำเสมอ

Use Temporary Credentials
ใช้สิทธิ์ชั่วคราวเมื่อจำเป็น

Key IAM Terms and Concepts

คำศัพท์และแนวคิดสำคัญที่เกี่ยวข้องกับ Identity and Access Management (IAM) เพื่อใช้ในการจัดการตัวตน ยืนยันตัวตน กำหนดสิทธิ์การเข้าถึง และตรวจสอบการใช้งานทรัพยากรบน Cloud



Identity

ตัวตนของผู้ใช้หรือระบบที่ใช้ในการเข้าถึงทรัพยากรบน Cloud

- **ตัวอย่าง:** ผู้ใช้ทั่วไป, กลุ่มผู้ใช้, บัญชีบริการ (Service Account)



Authentication (AuthN)

กระบวนการยืนยันตัวตนว่าผู้ใช้เป็นใครก่อนที่จะอนุญาตให้เข้าสู่ระบบ

- **ตัวอย่าง:** Password, MFA, Certificate, Biometric



Authorization (AuthZ)

กระบวนการตรวจสอบว่าผู้ใช้สามารถทำอะไรได้บ้างหลังจากยืนยันตัวตนแล้ว

- **ตัวอย่าง:** อนุญาตให้อ่าน เขียน หรือลบข้อมูลตาม Role, Policy หรือ Attribute



SSO (Single Sign-On)

การเข้าสู่ระบบเพียงครั้งเดียว เพื่อใช้งานหลายระบบ โดยไม่ต้องกรอกข้อมูลซ้ำในแต่ละบริการ

- **ตัวอย่าง:** Microsoft Entra ID, Google Workspace, SAML, OAuth, OIDC



MFA (Multi-Factor Authentication)

การยืนยันตัวตนด้วยหลายปัจจัย เพื่อลดความเสี่ยงจากการถูกขโมยรหัสผ่าน

- **ตัวอย่าง:** Password + OTP, Password + App, Password + Hardware Key



Role

กลุ่มของสิทธิ์ (Permission) ที่กำหนดตามหน้าที่หรือความรับผิดชอบของผู้ใช้

- **ตัวอย่าง:** Administrator, Developer, Security Auditor, Read-Only Role



Permission

สิทธิ์ในการดำเนินการกับทรัพยากร เช่น อ่าน เขียน ลบ หรือแก้ไขการตั้งค่า

- **ตัวอย่าง:** Read, Write, Delete, Manage



Policy

กฎที่ใช้กำหนดว่าใคร (Identity) สามารถทำอะไร (Action) กับทรัพยากรใด (Resource) ภายใต้เงื่อนไขใด (Condition)

- **ตัวอย่าง:** Allow Read S3, Deny Delete DB, จำกัดตาม IP หรือเวลา



Resource

ทรัพยากรบน Cloud ที่สามารถถูกเข้าถึงได้ เช่น เครื่องเสมือน, Storage, Database หรือ API

- **ตัวอย่าง:** EC2/VM, S3/Storage, RDS/Database, API/Service



RBAC (Role-Based Access Control)

การกำหนดสิทธิ์การเข้าถึงโดยใช้บทบาท (Role) เป็นหลัก เหมาะสำหรับองค์กรที่มีโครงสร้างชัดเจน

- **ตัวอย่าง:** Admin Role, Developer Role, Read-Only Role



ABAC (Attribute-Based Access Control)

การกำหนดสิทธิ์การเข้าถึงโดยใช้คุณลักษณะ (Attribute) ของผู้ใช้ ทรัพยากร และสภาพแวดล้อม เพื่อให้มีความยืดหยุ่นมากขึ้น

- **ตัวอย่าง:** Department = Finance, Environment = Production, Device = Compliant



Service Account

บัญชีที่ใช้โดยแอปพลิเคชันหรือบริการเพื่อเชื่อมต่อกับทรัพยากรบน Cloud โดยไม่ใช้บัญชีของบุคคล

- **ตัวอย่าง:** Application Access, Automation, CI/CD Pipeline



Auditing and Logging

การบันทึกและตรวจสอบกิจกรรมการใช้งาน IAM เพื่อตรวจหาความผิดปกติและใช้ในการตรวจสอบเหตุการณ์

- **ตัวอย่าง:** Login Log, Policy Change, Access Log



Federation

การเชื่อมต่อ Identity จากแหล่งภายนอกเพื่อใช้ในการยืนยันตัวตน

- **ตัวอย่าง:** SAML, OpenID Connect (OIDC), External Identity Provider



Least Privilege

หลักการให้สิทธิ์เท่าที่จำเป็นต่อการทำงานเพื่อลดความเสี่ยงหากบัญชีถูกโจมตีหรือถูกขโมย

- **ตัวอย่าง:** Developer ไม่มีสิทธิ์ลบ Production DB ให้เฉพาะสิทธิ์ที่จำเป็น

ตัวอย่างระบบงาน: ระบบลงทะเบียนนักศึกษา (Student Registration System)

ภาพรวมระบบ

มหาวิทยาลัยต้องการพัฒนาระบบลงทะเบียนนักศึกษา บน Cloud เพื่อให้นักศึกษา อาจารย์ และเจ้าหน้าที่ สามารถใช้งานได้อย่างสะดวก รวดเร็ว และปลอดภัย โดยระบบรองรับการลงทะเบียนเรียน ดูรายวิชา ตรวจสอบผลการลงทะเบียน และออกรายงานต่าง ๆ

ความต้องการของระบบ

- นักศึกษาสามารถลงทะเบียนเรียน และดูผลการลงทะเบียนของตนเองได้
- อาจารย์สามารถดูรายชื่อนักศึกษาในรายวิชาที่สอน และบันทึกคะแนนได้
- เจ้าหน้าที่สามารถจัดการรายวิชา เปิด-ปิดการลงทะเบียน และตรวจสอบข้อมูล
- ผู้บริหารสามารถดูรายงานภาพรวม เช่น จำนวนผู้ลงทะเบียนในแต่ละภาคการศึกษา
- ระบบต้องมีความปลอดภัย และป้องกันการเข้าถึงข้อมูลที่ไม่เหมาะสม

ผู้ใช้งานและบทบาท (ตัวอย่าง)



นักศึกษา

- ลงทะเบียนเรียน
- ดูผลการลงทะเบียน
- ดูตารางเรียน
- พิมพ์ใบรายงาน



อาจารย์

- ดูรายชื่อนักศึกษา
- บันทึกคะแนน
- ดูผลการเรียน
- ดูรายวิชาที่สอน



เจ้าหน้าที่

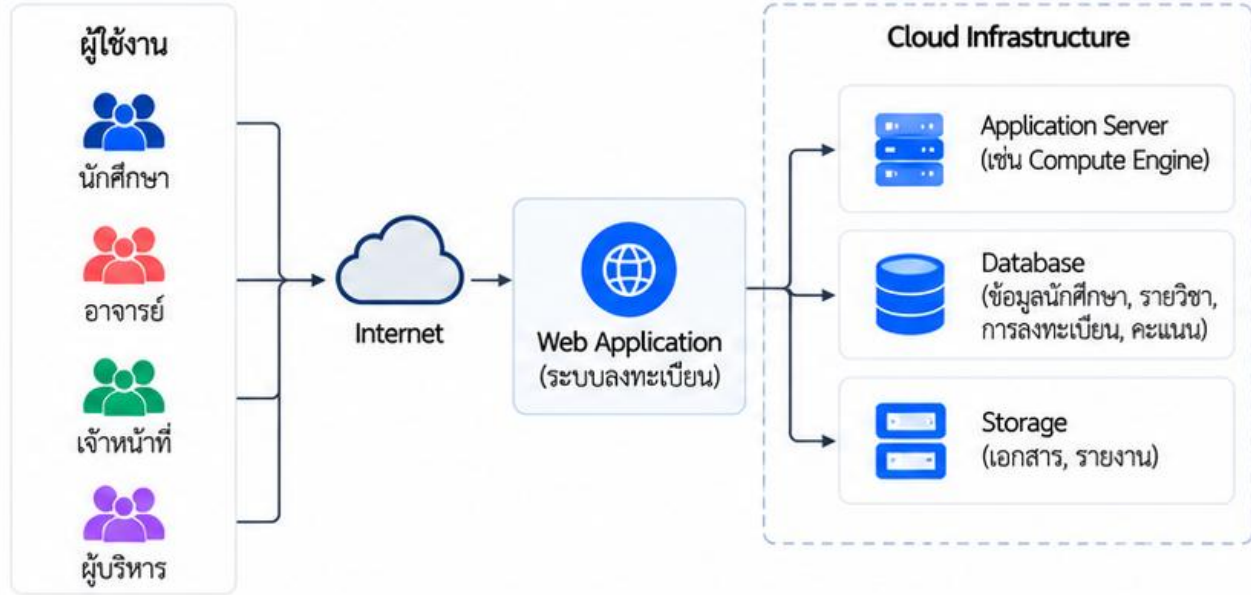
- จัดการรายวิชา
- เปิด-ปิดการลงทะเบียน
- ตรวจสอบข้อมูล
- ออกรายงาน



ผู้บริหาร

- ดูรายงานภาพรวม
- วิเคราะห์ข้อมูล
- กำหนดนโยบาย

สถาปัตยกรรมระบบ (ภาพรวม)



ปัญหาที่อาจเกิดขึ้นหากไม่มีการจัดการ IAM ที่เหมาะสม

เข้าถึงข้อมูลเกินสิทธิ์	เช่น นักศึกษาสามารถดูหรือแก้ไขคะแนนของผู้อื่นได้
ใช้บัญชีร่วมกัน	เช่น เจ้าหน้าที่หลายคนใช้บัญชีเดียวกัน ทำให้ตรวจสอบไม่ได้ว่าใครทำอะไร
บัญชีถูกโจมตี	หากไม่มี MFA อาจถูกขโมยรหัสผ่านและเข้าถึงข้อมูลสำคัญได้
ไม่มีการตรวจสอบการใช้งาน	ไม่สามารถทราบได้ว่าใครเข้าถึงหรือแก้ไขข้อมูลอะไร เมื่อใด
ผู้ใช้ภายนอกเข้าถึงระบบ	หากไม่มีการควบคุมสิทธิ์ อาจมีบุคคลภายนอกเข้าถึงระบบและข้อมูลได้

ออกแบบการแก้ปัญหาด้วย IAM สำหรับระบบลงทะเบียนนักศึกษา

ใช้หลักการ Identity and Access Management (IAM) เพื่อยืนยันตัวตน กำหนดสิทธิ์การเข้าถึง และควบคุมการใช้งานทรัพยากรบน Cloud ให้เหมาะสมกับบทบาทของผู้ใช้งานแต่ละกลุ่ม

กำหนดกลุ่มผู้ใช้งานและบทบาท (Roles)



นักศึกษา
(Student)

- ลงทะเบียนเรียน
- ดูผลการลงทะเบียน และตารางเรียน
- ดูคะแนน และพิมพ์รายงานของตนเอง



อาจารย์
(Instructor)

- ดูรายชื่อนักศึกษาในรายวิชาที่สอน
- บันทึกและแก้ไขคะแนน
- ดูตารางสอน และออกรายงานรายวิชา



เจ้าหน้าที่
(Registrar Staff)

- จัดการรายวิชาและตารางเรียน
- เปิด-ปิดการลงทะเบียน
- ตรวจสอบและแก้ไขข้อมูลการลงทะเบียน
- ออกรายงาน



ผู้บริหาร
(Administrator)

- ดูรายงานภาพรวมทั้งหมด
- วิเคราะห์ข้อมูลสถิติ
- จัดการผู้ใช้งานและสิทธิ์ (IAM)
- กำหนดนโยบายการใช้งานระบบ

สถาปัตยกรรม IAM ของระบบ (ภาพรวมแนวคิด)



ตัวอย่างการกำหนดสิทธิ์การเข้าถึง (Permission Mapping)

ทรัพยากร / การดำเนินการ	นักศึกษา	อาจารย์	เจ้าหน้าที่	ผู้บริหาร
ดูข้อมูลตนเอง (โปรไฟล์, ผลการลงทะเบียน)	✓	×	✓	✓
ลงทะเบียนเรียน	✓	×	✓	×
ดูรายชื่อนักศึกษาในรายวิชาที่สอน	×	✓	✓	✓
บันทึก/แก้ไขคะแนน	×	✓	×	×
จัดการรายวิชาและตารางเรียน	×	×	✓	✓
ดูรายงานภาพรวมทั้งหมด	×	×	✓	✓
จัดการผู้ใช้งานและสิทธิ์ (IAM)	×	×	×	✓

หลักการออกแบบ

Least Privilege
ให้สิทธิ์เท่าที่จำเป็น

Separation of Duties
แยกหน้าที่เพื่อลดความเสี่ยง

Regular Review
ตรวจสอบสิทธิ์อย่างสม่ำเสมอ

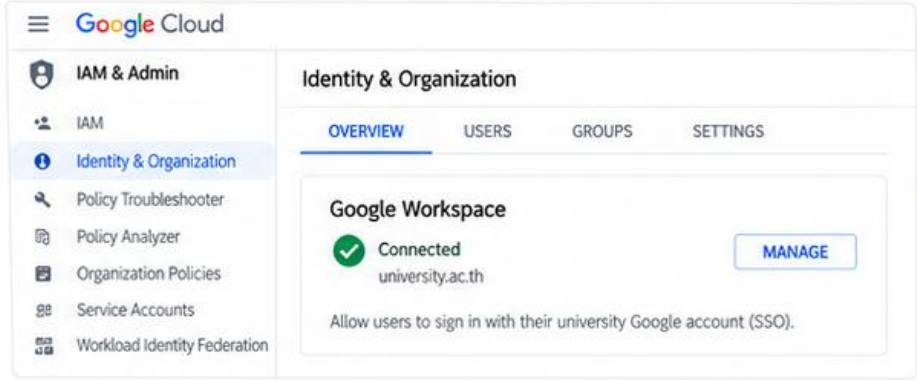
Audit Logging
บันทึกและตรวจสอบการใช้งาน

วิธีการตั้งค่า IAM สำหรับระบบลงทะเบียนนักศึกษา บน Google Cloud Platform

ตัวอย่างขั้นตอนการตั้งค่า IAM โดยใช้ Google Workspace สำหรับการยืนยันตัวตน (SSO) และกำหนดสิทธิ์การเข้าถึงทรัพยากรตามบทบาท (Role)

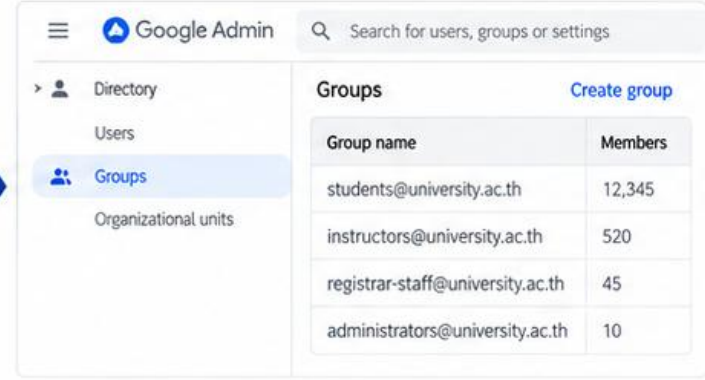
1 เตรียมการและเชื่อมต่อ Google Workspace (SSO)

เชื่อมต่อระบบกับ Google Workspace เพื่อให้ผู้ใช้ (นักศึกษา, อาจารย์, เจ้าหน้าที่, ผู้บริหาร)
สามารถเข้าสู่ระบบด้วยบัญชีมหาวิทยาลัย



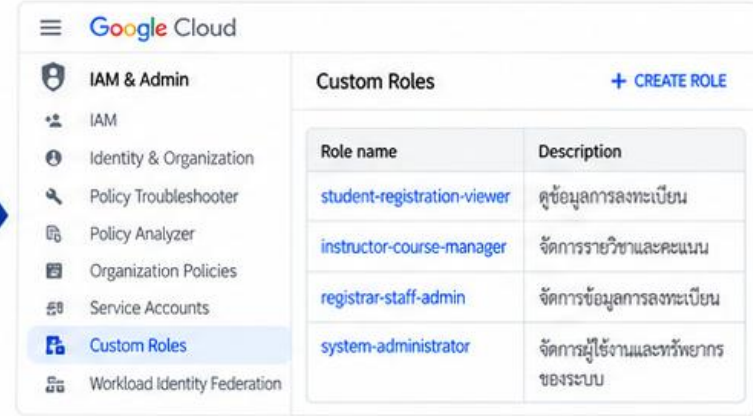
2 สร้างกลุ่มผู้ใช้งาน (Groups)

สร้างกลุ่มใน Google Workspace ตามบทบาทของผู้ใช้งาน เช่น students, instructors, registrar-staff, administrators



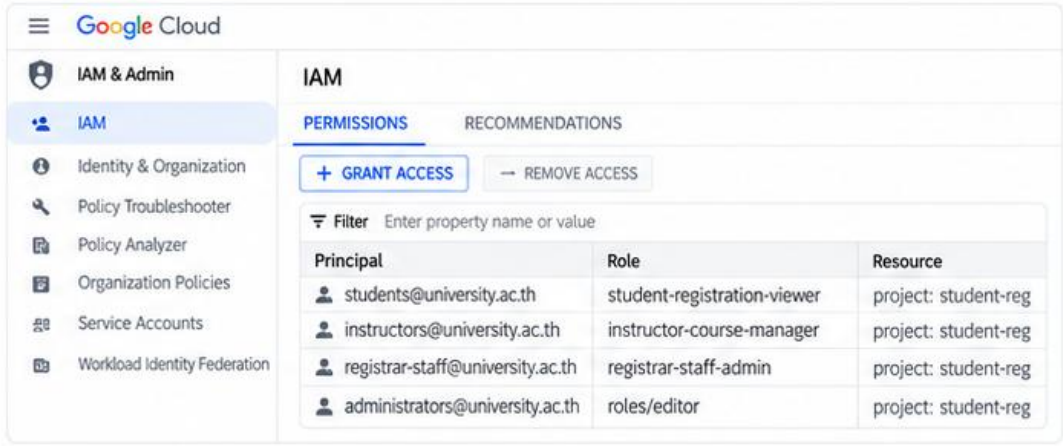
3 สร้าง IAM Roles (ถ้าต้องการ)

สร้าง Custom Roles ตามความต้องการของระบบ เพื่อกำหนดสิทธิ์ให้เหมาะสมกับแต่ละบทบาท



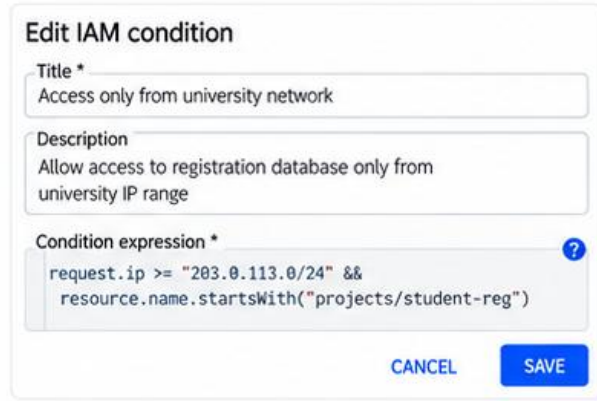
4 กำหนดสิทธิ์ให้กลุ่มผู้ใช้ (IAM Binding)

มอบบทบาทให้กับกลุ่มผู้ใช้บนระดับทรัพยากร (เช่น Project หรือเฉพาะบริการ)



5 ตั้งค่าเงื่อนไขการเข้าถึง (IAM Conditions)

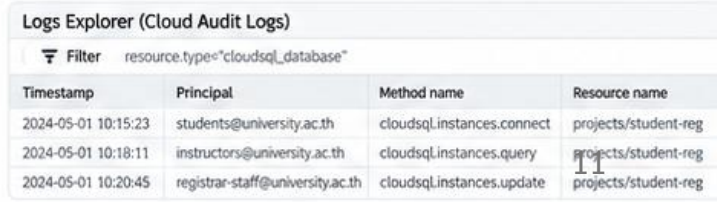
กำหนดเงื่อนไขเพิ่มเติม เช่น อนุญาตเฉพาะช่วงเวลา หรือจากเครือข่ายของมหาวิทยาลัย



6 ทดสอบการใช้งาน

เข้าสู่ระบบด้วยบัญชี Google Workspace ตามบทบาทต่าง ๆ และตรวจสอบว่าสามารถเข้าถึงทรัพยากรได้ตามสิทธิ์ที่กำหนด

- ทดสอบ Login ด้วยบัญชีมหาวิทยาลัย (SSO)
- ตรวจสอบสิทธิ์การเข้าถึงแต่ละบริการ (เช่น Cloud SQL, Storage)
- ทดสอบการเข้าถึงของแต่ละกลุ่มผู้ใช้ (นักศึกษา, อาจารย์, เจ้าหน้าที่, ผู้บริหาร)
- ตรวจสอบ Cloud Audit Logs ว่ามีการใช้งานตามนโยบาย
- ปรับแต่งสิทธิ์เพิ่มเติมตามผลการทดสอบ

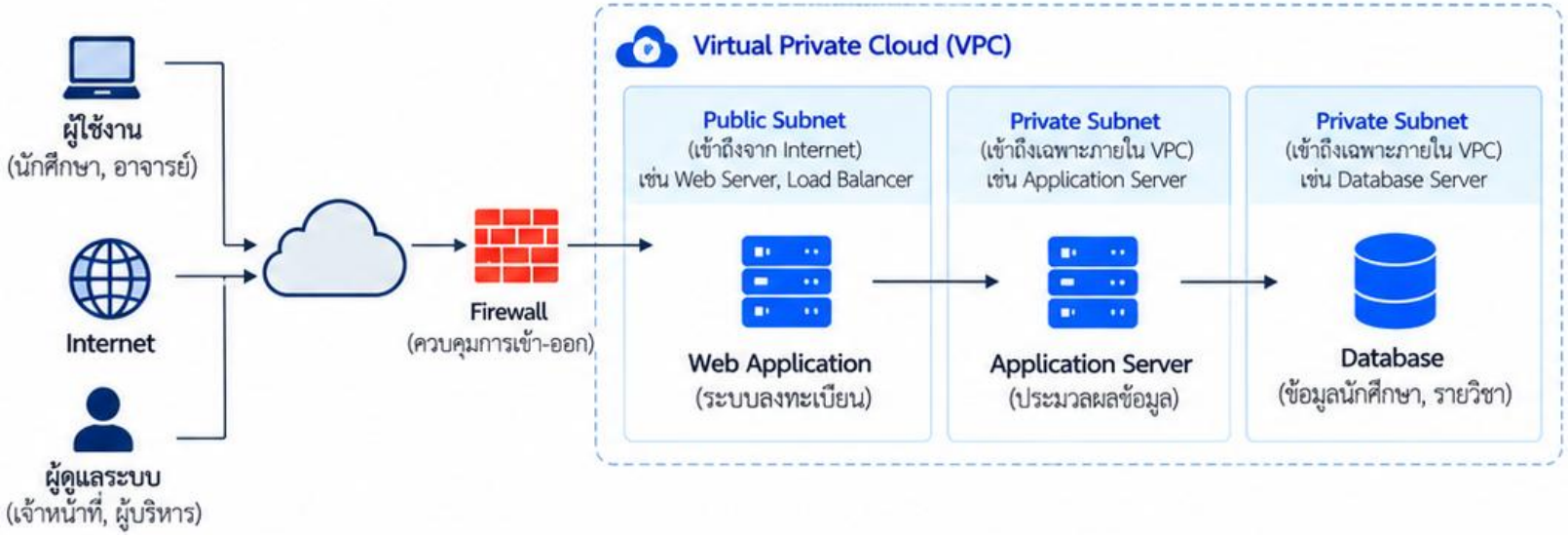


Network Security

Cloud Network Security: ความหมายและองค์ประกอบสำคัญ

Network Security คือ การป้องกันและควบคุมการเชื่อมต่อเครือข่าย เพื่อให้ระบบและข้อมูลบน Cloud ปลอดภัยจากการเข้าถึงที่ไม่ได้รับอนุญาต
โดยใช้การออกแบบเครือข่าย การกำหนดกฎไฟร์วอลล์ และการควบคุมการเข้าถึงตามหลักการความปลอดภัย

ภาพรวมการเชื่อมต่อเครือข่ายบน Cloud



ประเภทของการเชื่อมต่อเครือข่าย

Public Network (เข้าถึงจาก Internet)

- สามารถเข้าถึงได้จากอินเทอร์เน็ต
- เหมาะสำหรับบริการที่ต้องให้ผู้ใช้งานภายนอกเข้าถึง
- เช่น Web Application, Load Balancer
- ควรมีการควบคุมการเข้าถึงด้วย Firewall

Private Network (เข้าถึงเฉพาะภายใน VPC)

- ไม่สามารถเข้าถึงจากอินเทอร์เน็ตโดยตรง
- เหมาะสำหรับทรัพยากรที่มีข้อมูลสำคัญ
- เช่น Application Server, Database
- ลดความเสี่ยงจากการโจมตีภายนอก

ประโยชน์ของ Network Security บน Cloud

- ป้องกันการเข้าถึงที่ไม่ได้รับอนุญาต
- ลดความเสี่ยงต่อการโจมตีจากภายนอก
- ควบคุมการเชื่อมต่อตามหลัก Least Privilege
- เพิ่มความมั่นคงปลอดภัยและความพร้อมใช้งานของระบบ

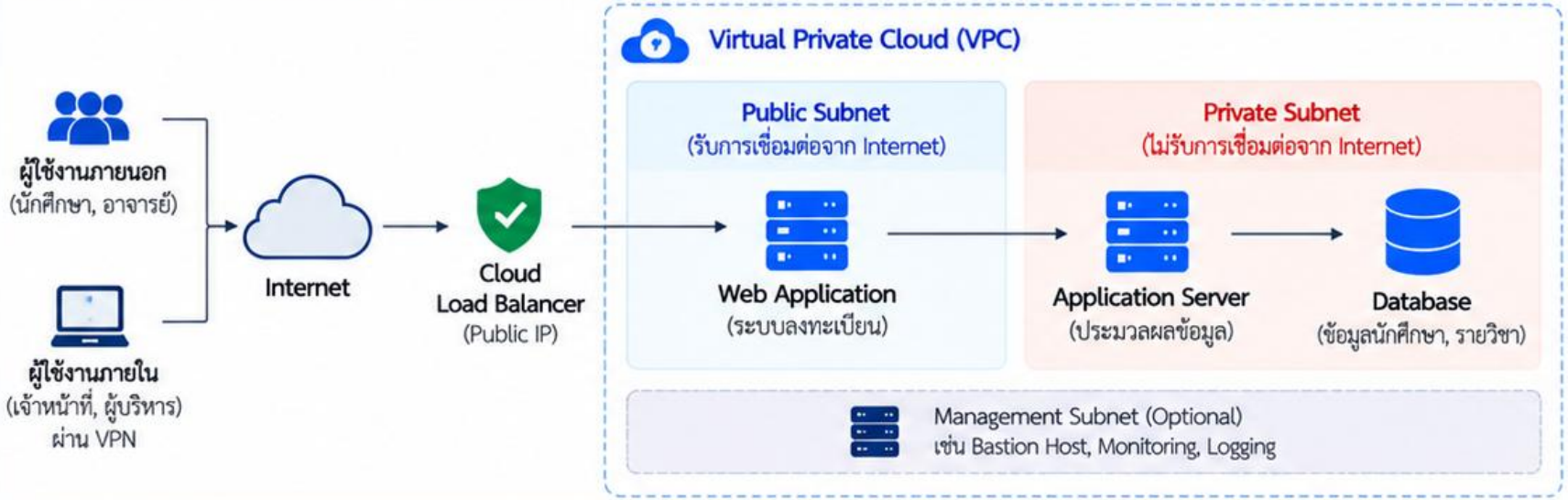
คำศัพท์สำคัญ (Key Terms)

คำศัพท์	ความหมาย
Network Security	การป้องกันและควบคุมการเชื่อมต่อเครือข่าย เพื่อป้องกันการเข้าถึงที่ไม่ได้รับอนุญาต
Virtual Private Cloud (VPC)	เครือข่ายเสมือนส่วนตัวบน Cloud ใช้แยกทรัพยากรขององค์กรจากเครือข่ายอื่น
Subnet	การแบ่งเครือข่ายย่อยภายใน VPC เช่น Public Subnet และ Private Subnet
Firewall	ระบบควบคุมการรับ-ส่งข้อมูล (Traffic) ตามกฎที่กำหนด เช่น อนุญาตหรือปฏิเสธ
Firewall Rule	กฎที่กำหนดว่าอนุญาตหรือปฏิเสธการเชื่อมต่อจากแหล่งที่มา (IP, Port, Protocol) ใด
Ingress	การรับข้อมูลเข้ามายังระบบ (Inbound Traffic) เช่น ผู้ใช้เข้าถึง Web Server
Egress	การส่งข้อมูลออกจากระบบ (Outbound Traffic) เช่น Web Server ออกไปยัง Internet
Network Segmentation	การแบ่งเครือข่ายออกเป็นส่วน ๆ เพื่อจำกัดการเข้าถึงและลดความเสี่ยง
Public IP	หมายเลข IP ที่สามารถเข้าถึงได้จาก Internet
Private IP	หมายเลข IP ที่เข้าถึงได้เฉพาะภายใน VPC
Zero Trust	แนวคิดด้านความปลอดภัยที่ไม่เชื่อใจใครโดยอัตโนมัติ และต้องตรวจสอบทุกการเข้าถึง
VPN	การเชื่อมต่อเครือข่ายอย่างปลอดภัย จากภายนอกเข้าสู่ VPC
Load Balancer	กระจายการรับส่งข้อมูลไปยังหลายเซิร์ฟเวอร์ และช่วยเพิ่มความพร้อมใช้งาน (High Availability)

การออกแบบเครือข่ายสำหรับระบบลงทะเบียนนักศึกษาบน Cloud

ออกแบบเครือข่ายโดยใช้ Virtual Private Cloud (VPC) และแบ่งเครือข่ายเป็น Public Subnet และ Private Subnet
เพื่อแยกส่วนการให้บริการ ลดความเสี่ยง และควบคุมการเข้าถึงระบบได้อย่างปลอดภัย

สถาปัตยกรรมเครือข่าย (Network Architecture)



แนวคิดการออกแบบ

1. แยกเครือข่ายเป็น **Public** และ **Private Subnet** เพื่อจำกัดการเข้าถึงทรัพยากรที่สำคัญ
2. ใช้ Cloud Load Balancer สำหรับรับการเชื่อมต่อจากผู้ใช้งานภายนอก และกระจายโหลดไปยัง Web Application
3. วาง **Database** ไว้ใน **Private Subnet** เพื่อป้องกันการเข้าถึงจาก Internet โดยตรง
4. ผู้ใช้งานภายใน เช่น เจ้าหน้าที่ สามารถเข้าถึงระบบผ่าน VPN หรือผ่านเครือข่ายของมหาวิทยาลัย
5. กำหนด **Firewall Rules** เพื่อควบคุมการรับ-ส่งข้อมูลระหว่างแต่ละส่วนของระบบ

หน้าที่ของแต่ละส่วน

องค์ประกอบ	หน้าที่	ตัวอย่างการใช้งานในระบบลงทะเบียนนักศึกษา
VPC	เครือข่ายเสมือนบน Cloud	สร้างเครือข่ายสำหรับระบบทั้งหมด
Public Subnet	รองรับทรัพยากรที่ต้องเข้าถึงจาก Internet	วาง Web Application และ Load Balancer
Private Subnet	รองรับทรัพยาการที่ไม่ต้องเข้าถึงจาก Internet	วาง Application Server และ Database
Cloud Load Balancer	กระจายโหลดและให้บริการผ่าน Public IP	รับการเชื่อมต่อจากนักศึกษาและส่งไปยัง Web Application
Web Application	ให้บริการระบบลงทะเบียน	แสดงหน้าเว็บ ลงทะเบียน ดูผลการลงทะเบียน
Application Server	ประมวลผลคำขอและเชื่อมต่อกับฐานข้อมูล	จัดการตรรกะของระบบ
Database	เก็บข้อมูลนักศึกษา รายวิชา การลงทะเบียน	เก็บข้อมูลสำคัญของระบบ
Management Subnet	ใช้สำหรับบริหารจัดการและตรวจสอบระบบ	เช่น Bastion Host, Monitoring, Logging

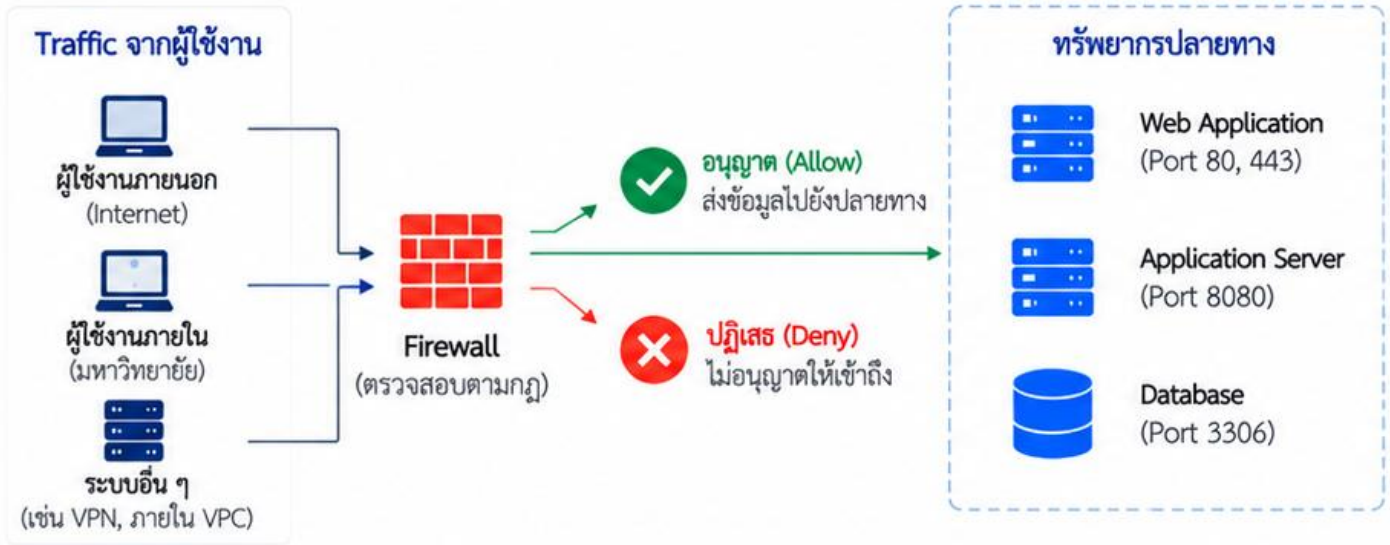
ประโยชน์ของการออกแบบเครือข่ายแบบนี้

- เพิ่มความปลอดภัย โดยแยกส่วนการให้บริการ
- ป้องกันการเข้าถึงฐานข้อมูลจาก Internet โดยตรง
- ควบคุมการรับ-ส่งข้อมูลด้วย Firewall Rules
- รองรับการขยายระบบในอนาคต (Scalability)
- บริหารจัดการและตรวจสอบการใช้งานได้ง่าย
- สอดคล้องกับแนวทาง Zero Trust

การควบคุมการเข้าถึงด้วย Firewall และ Network Access Control

Firewall คือ กลไกในการควบคุมการรับ-ส่งข้อมูล (Traffic) ระหว่างเครือข่าย โดยกำหนดกฎ (Firewall Rules) ว่าอนุญาตหรือปฏิเสธการเชื่อมต่อจากแหล่งที่มาไปยังปลายทาง ตามเงื่อนไขต่าง ๆ เช่น IP, Port, Protocol เพื่อป้องกันการเข้าถึงระบบที่ไม่เหมาะสม

หลักการทำงานของ Firewall



ประเภทของ Firewall Rules

Ingress Rules (การรับข้อมูลเข้า)

- ควบคุมการรับข้อมูลจากภายนอกหรือจากเครือข่ายอื่น เข้าสู่ทรัพยากรใน VPC
- กำหนดว่าอนุญาตหรือปฏิเสธการเชื่อมต่อเข้ามา
- ตัวอย่าง: อนุญาตให้ผู้ใช้งานภายนอกเข้าถึง Web Application ที่ Port 443

Egress Rules (การส่งข้อมูลออก)

- ควบคุมการส่งข้อมูลออกจากทรัพยากรใน VPC ไปยังภายนอกหรือเครือข่ายอื่น
- กำหนดว่าอนุญาตหรือปฏิเสธการเชื่อมต่อออกไป
- ตัวอย่าง: อนุญาตให้ Application Server เชื่อมต่อไปยัง Database ที่ Port 3306 และปิดการเชื่อมต่อออกไปยัง Internet ที่ไม่จำเป็น

ตัวอย่าง Firewall Rules สำหรับระบบลงทะเบียนนักศึกษา

ลำดับ	ชื่อกฎ	ทิศทาง	แหล่งที่มา (Source)	ปลายทาง (Target)	Protocol / Port	การกระทำ	คำอธิบาย
1	allow-https-web	Ingress	0.0.0.0/0 (Internet) →	Web Application	TCP 443	Allow	อนุญาตให้ผู้ใช้งานภายนอกเข้าถึงระบบลงทะเบียนผ่าน HTTPS
2	deny-ssh-from-internet	Ingress	0.0.0.0/0 (Internet)	Application Server	TCP 22	Deny	ปฏิเสธการเชื่อมต่อ SSH จากภายนอก
3	allow-app-to-db	Ingress	Application Server (Internal IP)	Database	TCP 3306	Allow	อนุญาตให้ Application Server เชื่อมต่อไปยัง Database
4	deny-all-ingress	Ingress	Any	All	All	Deny	ปฏิเสธการเชื่อมต่อเข้าที่ไม่ระบุไว้
5	allow-dns-egress	Egress	All (VPC)	DNS (8.8.8.8)	UDP/TCP 53	Allow	อนุญาตให้ใช้งาน DNS
6	deny-internet-egress	Egress	Application Server	0.0.0.0/0 (Internet)	All	Deny	ปฏิเสธการเชื่อมต่อออก Internet ที่ไม่จำเป็น

องค์ประกอบของ Firewall Rule

- **Source** — IP Address, Range, หรือ Network
- **Target** — ทรัพยากรที่ใช้กฎนี้ เช่น Instance, Subnet, Tag
- **Protocol / Port** — เช่น TCP, UDP, ICMP และหมายเลข Port
- **Action** — Allow หรือ Deny
- **Condition** — เงื่อนไขเพิ่มเติม เช่น IP Range, Tag, Service Account

แนวทางการตั้งค่า Firewall ที่ดี

- **อนุญาตเฉพาะ Traffic ที่จำเป็น** (Least Privilege)
- **ปฏิเสธการเข้าถึงที่ไม่จำเป็น** (Default Deny)
- **ใช้ IP Range ที่ชัดเจน และจำกัดเฉพาะแหล่งที่เชื่อถือได้**
- **ตรวจสอบและทบทวนกฎอย่างสม่ำเสมอ** (Monitor & Review)

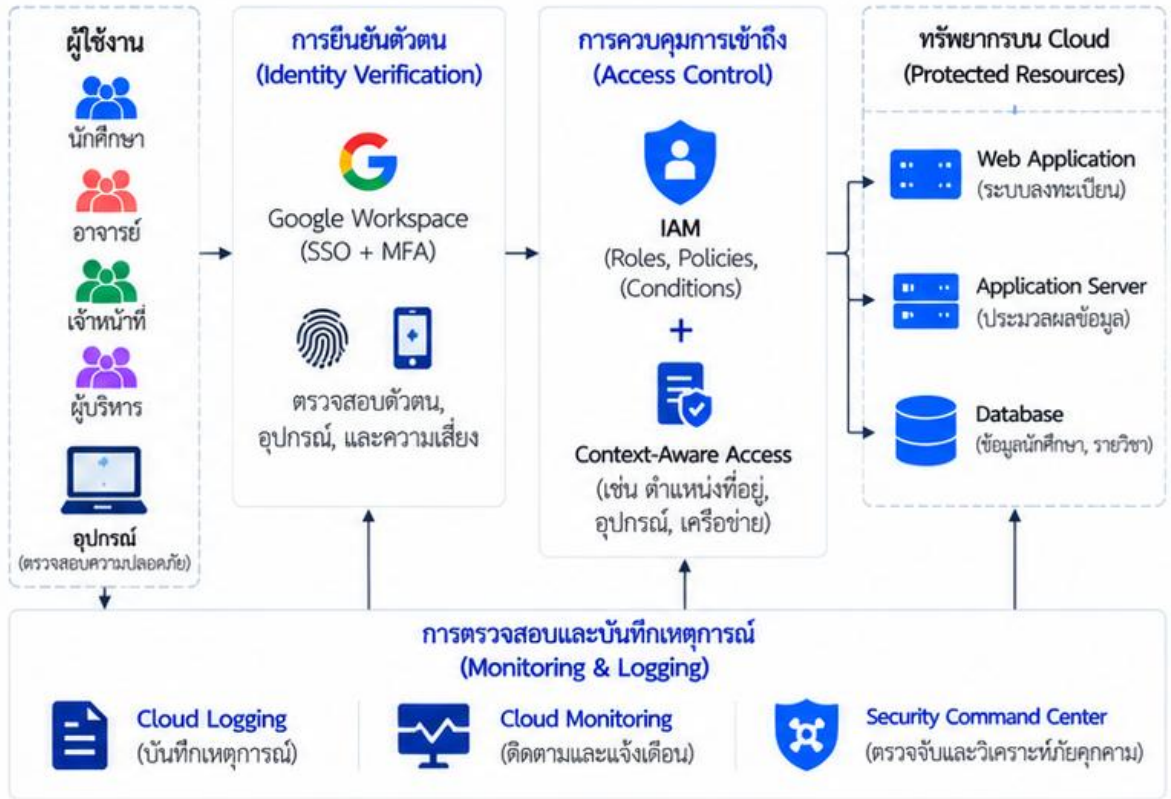
Zero Trust Architecture สำหรับระบบลงทะเบียนนักศึกษา

Zero Trust คือ แนวทางการรักษาความปลอดภัยที่ไม่เชื่อถือผู้ใช้งานหรืออุปกรณ์ใดโดยอัตโนมัติ (Never Trust, Always Verify) โดยทุกการเข้าถึงระบบจะต้องผ่านการตรวจสอบตัวตน สิทธิ์การเข้าถึง และบริบทตามความเสี่ยง แม้จะอยู่ภายในเครือข่ายเดียวกันก็ตาม

หลักการสำคัญของ Zero Trust

1. **Never Trust, Always Verify**
   ไม่เชื่อถือการเข้าถึงใด ๆ โดยอัตโนมัติ ตรวจสอบทุกครั้ง
2. **Verify Identity**
   ตรวจสอบตัวตนผู้ใช้งานและอุปกรณ์ก่อนเข้าถึงทรัพยากร
3. **Least Privilege Access**
   ให้สิทธิ์เฉพาะเท่าที่จำเป็นต่อการทำงาน
4. **Continuous Monitoring**
   ตรวจสอบและติดตามพฤติกรรมการเข้าถึงอย่างต่อเนื่อง
5. **Assume Breach**
   ออกแบบระบบโดยสมมติว่ามีการโจมตีเกิดขึ้นและจำกัดผลกระทบให้มากที่สุด

สถาปัตยกรรม Zero Trust สำหรับระบบลงทะเบียนนักศึกษา (ภาพรวม)



ประโยชน์ของ Zero Trust

- ลดความเสี่ยงจากการเข้าถึงโดยไม่ได้รับอนุญาต
- ป้องกันการเคลื่อนไหวด้านข้างของผู้โจมตี (Lateral Movement)
- ควบคุมการเข้าถึงตามบริบท (เช่น อุปกรณ์, ตำแหน่ง, ความเสี่ยง)
- เพิ่มความปลอดภัยให้กับข้อมูลสำคัญของนักศึกษา
- รองรับการทำงานแบบ Hybrid และ Remote
- ตรวจสอบและตอบสนองเหตุการณ์ได้รวดเร็ว

เปรียบเทียบแนวคิดการรักษาความปลอดภัย

Traditional Security	Zero Trust Security
เชื่อถือผู้ใช้ภายในเครือข่าย	ไม่เชื่อถือผู้ใช้หรืออุปกรณ์ใด
เข้าถึงได้เมื่ออยู่ใน Network	ตรวจสอบทุกการเข้าถึง
ควบคุมเฉพาะที่ขอบเครือข่าย	ควบคุมทุกทรัพยากร (ทุกชั้น)
ตรวจสอบเมื่อเกิดปัญหา	ตรวจสอบและติดตามต่อเนื่อง
เสี่ยงต่อการเคลื่อนไหวด้านข้าง	จำกัดผลกระทบหากถูกโจมตี

ตัวอย่างการนำ Zero Trust ไปใช้ในระบบลงทะเบียนนักศึกษา

- **ยืนยันตัวตนด้วย SSO + MFA**
  นักศึกษา อาจารย์ และเจ้าหน้าที่เข้าสู่ระบบผ่าน Google Workspace พร้อมเปิดใช้งาน MFA
- **ตรวจสอบอุปกรณ์**
  อนุญาตเฉพาะอุปกรณ์ที่มีความปลอดภัยตามนโยบาย (เช่น มี Antivirus, ไม่ถูก Jailbreak)
- **จำกัดตำแหน่งที่อยู่ (IP/Location)**
  อนุญาตการเข้าถึงระบบจากเครือข่ายของมหาวิทยาลัย หรือตำแหน่งที่กำหนดเท่านั้น
- **กำหนดสิทธิ์ตามบทบาท**
  ควบคุมการเข้าถึงตามบทบาท (นักศึกษา, อาจารย์, เจ้าหน้าที่, ผู้บริหาร) ด้วย IAM และเงื่อนไขเพิ่มเติม
- **ตรวจสอบและบันทึกเหตุการณ์**
  ใช้ Cloud Logging และ Monitoring เพื่อตรวจสอบพฤติกรรมการใช้งานและแจ้งเตือนความผิดปกติ

กรณีศึกษา: การออกแบบความปลอดภัยเครือข่ายสำหรับระบบลงทะเบียนนักศึกษา

ออกแบบสถาปัตยกรรมเครือข่ายบน Google Cloud Platform เพื่อให้ระบบลงทะเบียนนักศึกษามีความปลอดภัย โดยแยกส่วนเครือข่าย กำหนดการเข้าถึงด้วย Firewall Rules และป้องกันการเข้าถึงทรัพยากรสำคัญจาก Internet โดยตรง

ความต้องการของระบบ

ผู้ใช้งานภายนอก
(นักศึกษา, อาจารย์)
เข้าถึงระบบลงทะเบียนผ่าน Internet

ผู้ใช้งานภายใน
(เจ้าหน้าที่, ผู้บริหาร)
เข้าถึงระบบผ่าน VPN หรือเครือข่ายมหาวิทยาลัย

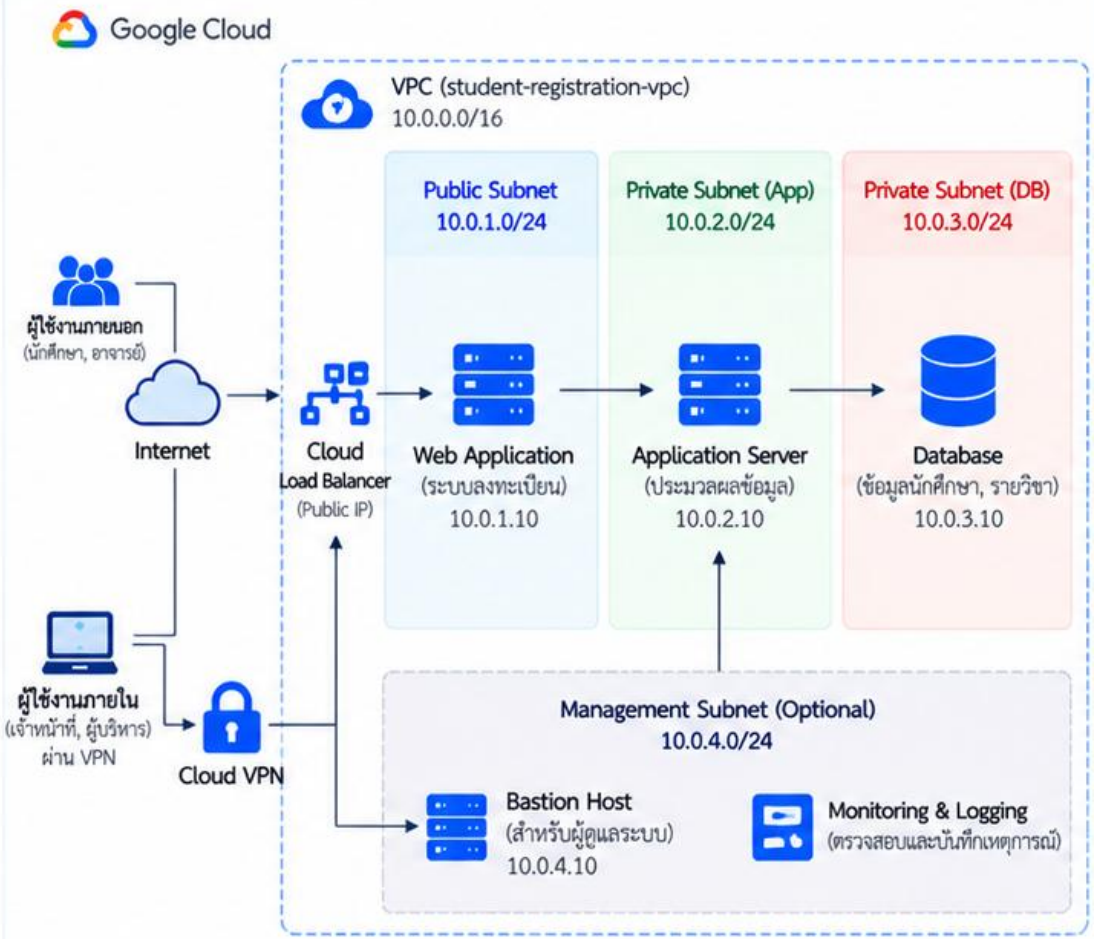
ระบบมีความปลอดภัย
ป้องกันการเข้าถึง Database และ Application Server จาก Internet โดยตรง

รองรับการใช้งานในอนาคต
สามารถขยายระบบได้ และบริหารจัดการได้ง่าย

เป้าหมายด้านความปลอดภัย

- แยกส่วนเครือข่ายตามบทบาทของระบบ
- อนุญาตเฉพาะการเชื่อมต่อที่จำเป็น
- ป้องกันการเข้าถึงทรัพยากรสำคัญจาก Internet
- รองรับการเข้าถึงจากผู้ใช้งานภายในผ่าน VPN
- ลดความเสี่ยงจากการโจมตีและการเข้าถึงโดยไม่ได้รับอนุญาต

สถาปัตยกรรมเครือข่ายสำหรับระบบลงทะเบียนนักศึกษา



ตัวอย่าง Firewall Rules ที่สำคัญ

ลำดับ	ชื่อกฎ	ทิศทาง	แหล่งที่มา	ปลายทาง	Port	การกระทำ
1	allow-https	Ingress	0.0.0.0/0 (Internet)	Web App (10.0.1.10)	TCP 443	Allow
2	allow-http	Ingress	0.0.0.0/0 (Internet)	Web App (10.0.1.10)	TCP 80	Allow
3	allow-app	Ingress	Web App (10.0.1.0/24)	App Server (10.0.2.10)	TCP 8080	Allow
4	allow-db	Ingress	App Server (10.0.2.0/24)	Database (10.0.3.10)	TCP 3306	Allow
5	allow-vpn	Ingress	VPN Range (10.8.0.0/24)	Management (10.0.4.10)	TCP 22	Allow
6	deny-all	Ingress	0.0.0.0/0 (Internet)	Internal Resources	All	Deny

ผลลัพธ์ที่ได้จากการออกแบบ

ระบบมีความปลอดภัยมากขึ้น
ทรัพยากรสำคัญ (Application Server, Database) ไม่สามารถเข้าถึงจาก Internet โดยตรง

ควบคุมการเชื่อมต่อได้อย่างชัดเจน
อนุญาตเฉพาะการเชื่อมต่อที่จำเป็นตาม Firewall Rules

รองรับการใช้งานของผู้ใช้งานภายใน
เข้าถึงผ่าน VPN และ Bastion Host ด้วยความปลอดภัย

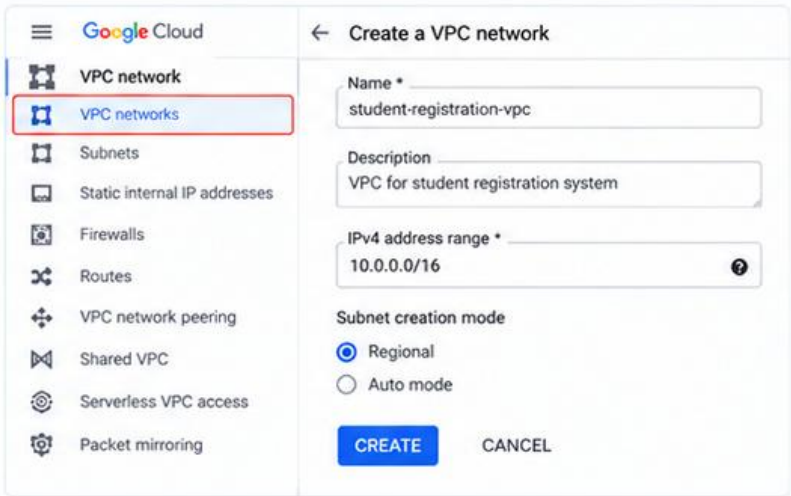
พร้อมสำหรับการขยายระบบในอนาคต
โครงสร้างเครือข่ายรองรับการเพิ่มบริการและการจัดการที่ซับซ้อนขึ้น

การตั้งค่า Network Security บน Google Cloud (ตัวอย่าง)

ตัวอย่างการตั้งค่าเครือข่ายสำหรับระบบลงทะเบียนนักศึกษา โดยสร้าง VPC, Subnet และ Firewall Rules พร้อมอธิบายว่ากำหนดแต่ละส่วนเพื่ออะไร เพื่อควบคุมการเข้าถึงทรัพยากรอย่างปลอดภัย

1. สร้าง VPC Network

สร้างเครือข่ายเสมือน (VPC) สำหรับระบบลงทะเบียนนักศึกษา เพื่อแยกเครือข่ายออกจากระบบอื่น และกำหนดช่วง IP Address

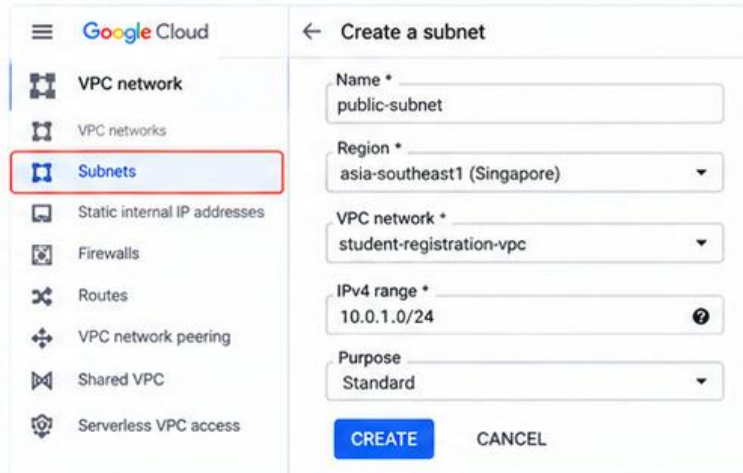


กำหนดตรงนี้เพื่ออะไร

- สร้างเครือข่ายเสมือนสำหรับระบบลงทะเบียนนักศึกษา
- กำหนดช่วง IP Address ของทั้งระบบ (10.0.0.0/16)
- แยกเครือข่ายออกจากระบบอื่น เพื่อเพิ่มความปลอดภัยและจัดการได้ง่าย

2. สร้าง Subnet

สร้าง Subnet สำหรับแต่ละส่วนของระบบ เช่น Public Subnet สำหรับ Web Application และ Private Subnet สำหรับ Application Server และ Database

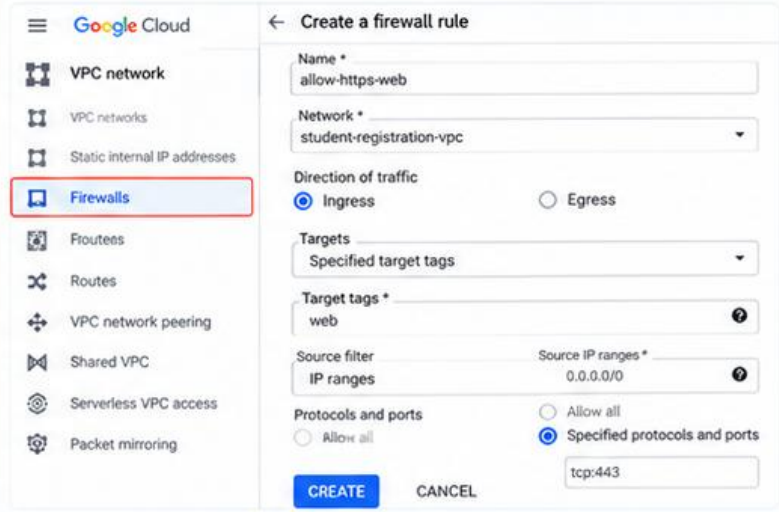


กำหนดตรงนี้เพื่ออะไร

- กำหนดช่วง IP ของ Subnet (เช่น 10.0.1.0/24)
- ระบุ Region ให้ใกล้ผู้ใช้งานเพื่อลดความหน่วง (Latency)
- แยก Public และ Private Subnet เพื่อควบคุมการเข้าถึงและลดความเสี่ยงจาก Internet

3. สร้าง Firewall Rule

กำหนดกฎการรับ-ส่งข้อมูลระหว่างเครือข่าย เพื่ออนุญาตเฉพาะการเชื่อมต่อที่จำเป็น และป้องกันการเข้าถึงที่ไม่เหมาะสม



กำหนดตรงนี้เพื่ออะไร

- กำหนดทิศทางการรับ-ส่งข้อมูล (Ingress/Egress)
- ระบุแหล่งที่มา (Source IP), โปรโตคอล (TCP/UDP) และ Port
- อนุญาตเฉพาะการเชื่อมต่อที่จำเป็น เช่น เปิดเฉพาะ TCP 443 สำหรับ Web
- ป้องกันการเข้าถึงระบบจากแหล่งที่ไม่ไว้วางใจ

ตัวอย่างการตั้งค่า Subnet และ Firewall Rules สำหรับระบบลงทะเบียนนักศึกษา

ส่วนประกอบ	ชื่อ	ช่วง IP Address	การเชื่อมต่อจาก Internet	ตัวอย่างการใช้งาน	เหตุผลในการกำหนด
Public Subnet	public-subnet	10.0.1.0/24	เชื่อมต่อได้	Web Application (Load Balancer)	ต้องรับการเชื่อมต่อจากผู้ใช้งานผ่าน Internet
Private Subnet (App)	app-subnet	10.0.2.0/24	ไม่เชื่อมต่อ	Application Server	ป้องกันการเข้าถึงจาก Internet โดยตรง
Private Subnet (DB)	db-subnet	10.0.3.0/24	ไม่เชื่อมต่อ	Database	ให้เข้าถึงได้เฉพาะจาก Application Server

ผลลัพธ์หลังการตั้งค่า

- ระบบมีโครงสร้างเครือข่ายที่ชัดเจนและแยกส่วนการให้บริการ
- ควบคุมการเข้าถึงด้วย Firewall Rules ตามหลัก Least Privilege
- ลดความเสี่ยงจากการเข้าถึงทรัพยากรสำคัญโดยตรงจาก Internet
- รองรับการขยายระบบในอนาคต และบริหารจัดการได้ง่าย
- สอดคล้องกับแนวทาง Zero Trust Architecture

Data Security & Encryption

ความรู้พื้นฐานด้าน Data Security

Data Security คือ การปกป้องข้อมูลจากการเข้าถึง การใช้งาน การเปิดเผย การแก้ไข หรือการทำลายโดยไม่ได้รับอนุญาต เพื่อให้ข้อมูลยังคงมีความลับ ความถูกต้อง และพร้อมใช้งานตลอดวงจรชีวิตของข้อมูล (Data Lifecycle) โดยครอบคลุมทั้งข้อมูลที่จัดเก็บ ส่งผ่าน และประมวลผลบนระบบ Cloud

ความหมายของ Data Security



Data Security คือ แนวทาง มาตรการ และเทคโนโลยีที่ใช้ในการปกป้องข้อมูลจากภัยคุกคามทั้งภายในและภายนอก เพื่อให้ข้อมูลมีความปลอดภัยตลอดวงจรชีวิตของข้อมูล ไม่ว่าจะอยู่ในรูปแบบใดหรืออยู่บนระบบใด เช่น ระบบ Cloud, Database, File Storage หรือระหว่างการส่งผ่านเครือข่าย

CIA Triad หลักการสำคัญของการปกป้องข้อมูล



Confidentiality
ความลับของข้อมูล

- ป้องกันการเข้าถึงข้อมูลโดยไม่ได้รับอนุญาต
- ควบคุมสิทธิ์การเข้าถึง
- ใช้การเข้ารหัส (Encryption)
- ใช้หลัก Least Privilege



Integrity
ความถูกต้องของข้อมูล

- ป้องกันการแก้ไขข้อมูลโดยไม่ได้รับอนุญาต
- ตรวจสอบความถูกต้องของข้อมูล
- ใช้ Hash, Digital Signature
- มีการบันทึกและตรวจสอบการเปลี่ยนแปลง (Audit Log)



Availability
ความพร้อมใช้งานของข้อมูล

- ให้สามารถเข้าถึงข้อมูลได้เมื่อจำเป็น
- ป้องกันการหยุดชะงักของระบบ
- ใช้การสำรองข้อมูล (Backup)
- ออกแบบระบบให้มีความทนทานต่อความผิดพลาด (High Availability)

ความสำคัญของ Data Security สำหรับระบบลงทะเบียนนักศึกษา



ข้อมูลส่วนบุคคลของนักศึกษา
เช่น ชื่อ-สกุล เลขประจำตัวนักศึกษา ที่อยู่



ข้อมูลการลงทะเบียน
เช่น รายวิชาที่ลงทะเบียน ผลการเรียน



ข้อมูลการชำระเงิน
เช่น ค่าธรรมเนียมการศึกษา



ข้อมูลภายในของมหาวิทยาลัย
เช่น ข้อมูลอาจารย์ หลักสูตร และเอกสารสำคัญ



หากข้อมูลรั่วไหล แก้ไขผิดพลาด หรือไม่สามารถใช้งานได้ อาจส่งผลต่อความเชื่อมั่นของนักศึกษาและมหาวิทยาลัย รวมถึงอาจมีผลทางกฎหมาย

วงจรชีวิตของข้อมูล (Data Lifecycle)



Create
สร้างข้อมูล
เช่น ลงทะเบียนนักศึกษา

→



Store
จัดเก็บข้อมูล
เช่น Database, Cloud Storage

→



Use
ใช้งานข้อมูล
เช่น ประมวลผลและแสดงผล

→



Share
แบ่งปันข้อมูล
เช่น ส่งข้อมูลให้หน่วยงานอื่น

→



Archive
เก็บข้อมูลระยะยาว
เช่น ข้อมูลนักศึกษาที่จบการศึกษาแล้ว

→



Delete
ลบข้อมูล
เมื่อหมดความจำเป็นตามนโยบายการเก็บรักษาข้อมูล

ต้องมีมาตรการรักษาความปลอดภัยในทุกขั้นตอนของวงจรชีวิตข้อมูล

การจัดประเภทข้อมูล (Data Classification)

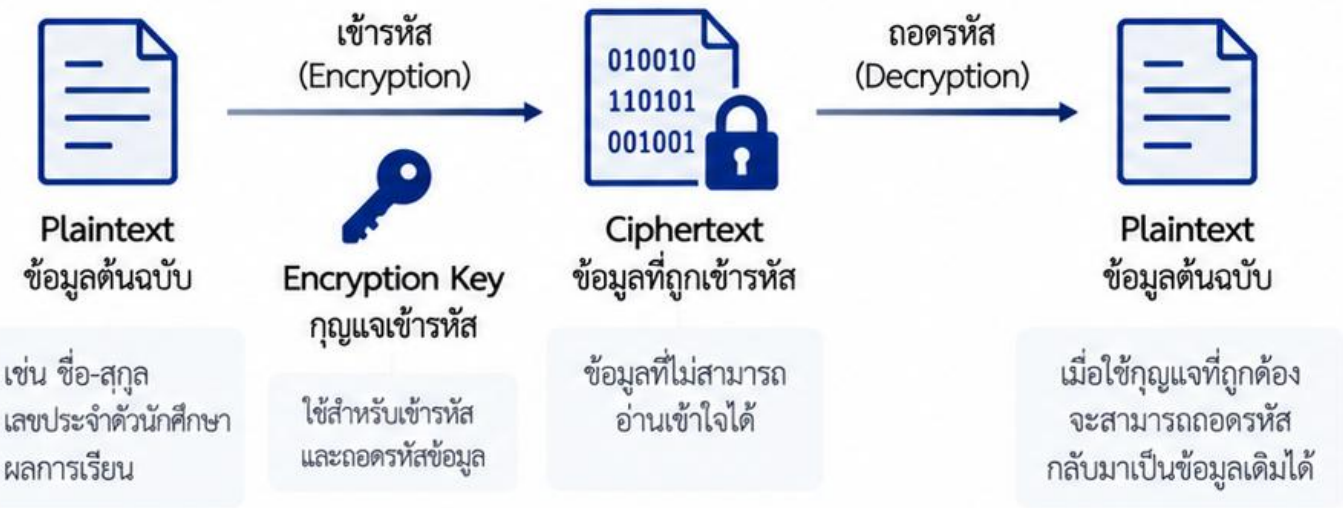
การจัดประเภทข้อมูลช่วยให้กำหนดมาตรการป้องกันที่เหมาะสมตามระดับความอ่อนไหว

ระดับ	ความหมาย	ตัวอย่างข้อมูล	มาตรการการปกป้อง
ลับมาก (Highly Confidential)	ข้อมูลที่มีความอ่อนไหวสูง หากรั่วไหลจะมีผลกระทบร้ายแรง	• เลขประจำตัวประชาชน • ข้อมูลสุขภาพ • ข้อมูลการเงิน	• เข้ารหัสข้อมูล • จำกัดการเข้าถึงอย่างเข้มงวด • ตรวจสอบและบันทึกการใช้งาน
ลับ (Confidential)	ข้อมูลสำคัญขององค์กร	• ข้อมูลการลงทะเบียน • ผลการเรียน • ข้อมูลบุคลากร	• กำหนดสิทธิ์การเข้าถึง • เข้ารหัสข้อมูล • ตรวจสอบการใช้งาน
ทั่วไป (Internal)	ข้อมูลภายในองค์กร	• เอกสารการทำงาน • ข้อมูลหลักสูตร • รายงานภายใน	• จำกัดการเข้าถึงตามบทบาท • ตรวจสอบการใช้งาน
สาธารณะ (Public)	ข้อมูลที่เผยแพร่ต่อสาธารณะได้	• ข้อมูลหลักสูตร • ประกาศมหาวิทยาลัย • ข้อมูลติดต่อ	• ตรวจสอบความถูกต้อง • ป้องกันการแก้ไขโดยไม่ได้รับอนุญาต

แนวคิดพื้นฐานของการเข้ารหัสข้อมูล (Encryption)

การเข้ารหัสข้อมูล (Encryption) คือ กระบวนการแปลงข้อมูลจากรูปแบบที่อ่านเข้าใจได้ (Plaintext) ให้อยู่ในรูปแบบที่ไม่สามารถอ่านได้ (Ciphertext) โดยใช้กุญแจเข้ารหัส (Encryption Key) เพื่อป้องกันไม่ให้ผู้ที่ไม่ได้รับอนุญาตเข้าถึงข้อมูล แม้ว่าข้อมูลจะถูกขโมยหรือดักจับระหว่างการส่งหรือการจัดเก็บ

หลักการทำงานของการเข้ารหัส



องค์ประกอบสำคัญของการเข้ารหัส

Plaintext (ข้อมูลต้นฉบับ)
ข้อมูลที่สามารถอ่านและเข้าใจได้ เช่น ข้อมูลนักศึกษา ผลการเรียน

Ciphertext (ข้อมูลที่ถูกเข้ารหัส)
ข้อมูลที่ไม่สามารถอ่านได้ หากไม่มีกุญแจที่ถูกต้อง

Encryption Key (กุญแจเข้ารหัส)
ใช้สำหรับเข้ารหัสและถอดรหัสข้อมูล มีหน้าที่ควบคุมการเข้าถึงข้อมูล

Encryption Algorithm (อัลกอริเธึ่มเข้ารหัส)
วิธีการทางคณิตศาสตร์ที่ใช้ในการเข้ารหัสและถอดรหัสข้อมูล
เช่น AES, RSA, ChaCha20

ตัวอย่างข้อมูลนักศึกษาก่อนและหลังการเข้ารหัส

Plaintext (ข้อมูลต้นฉบับ)

ชื่อ-สกุล:	นางสาวสมหญิง ใจดี
รหัสนักศึกษา:	661234567
สาขาวิชา:	วิทยาการคอมพิวเตอร์
ผลการเรียน:	3.75

เข้ารหัส
(Encryption)

Ciphertext (ข้อมูลที่ถูกเข้ารหัส)

```
f3a9b2e1c4d5f6789a0b1c2d3e4f
7a8b9c0d1e2f3a4b5c6d7e8f9a0b
c1d2e3f4a5b6c7d8e9f0a1b2c3d4
e5f6a7b8c9d0e1f2a3b4c5d6e7f8
```

ประโยชน์ของการเข้ารหัสข้อมูล

ป้องกันการเข้าถึงข้อมูลโดยไม่ได้รับอนุญาต
แม้ว่าข้อมูลจะถูกขโมยหรือดักจับ ก็ไม่สามารถอ่านได้หากไม่มีกุญแจที่ถูกต้อง

รักษาความลับของข้อมูลสำคัญ
เหมาะสำหรับข้อมูลส่วนบุคคล ข้อมูลการลงทะเบียน และผลการเรียน

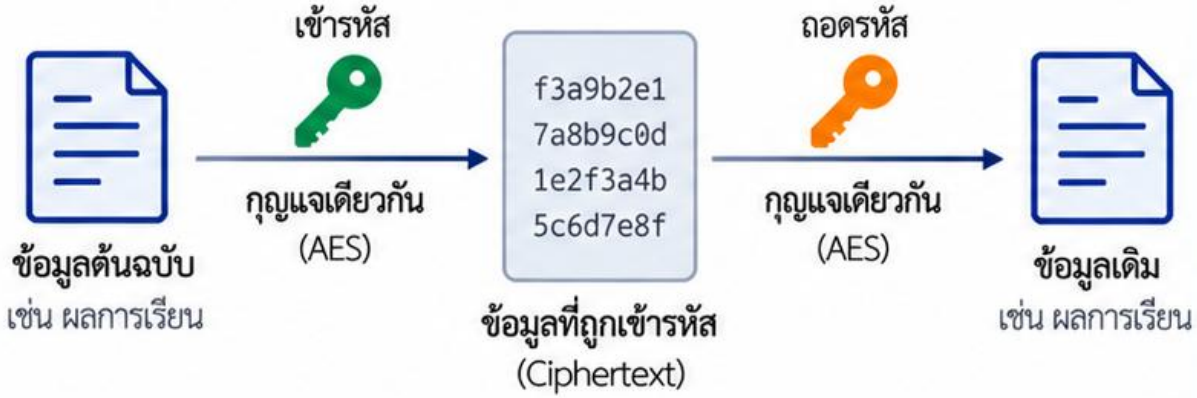
สร้างความเชื่อมั่นให้กับผู้ใช้งานและองค์กร
แสดงถึงการให้ความสำคัญกับการคุ้มครองข้อมูลและความเป็นส่วนตัว

ช่วยให้สอดคล้องกับกฎหมายและมาตรฐานด้านความปลอดภัยข้อมูล
เช่น PDPA และแนวปฏิบัติด้านความปลอดภัยของข้อมูลในระบบ Cloud

ตัวอย่างการใช้งาน Symmetric และ Asymmetric Encryption

Symmetric Encryption (ใช้กุญแจเดียวกัน)

ใช้กุญแจเดียวกันในการเข้ารหัสและถอดรหัส เหมาะสำหรับข้อมูลปริมาณมาก



ตัวอย่างการใช้งาน

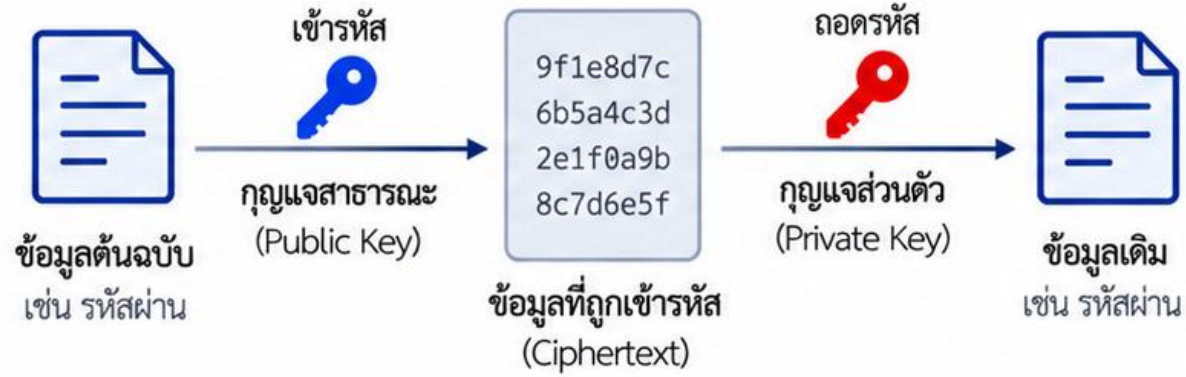
เข้ารหัสข้อมูลใน Cloud SQL
เช่น ข้อมูลนักศึกษาและผลการเรียน

เข้ารหัสไฟล์ใน Cloud Storage
เช่น เอกสารการสมัครและเอกสารผลการเรียน

เข้ารหัสข้อมูลสำรอง (Backup)
เช่น ข้อมูลทะเบียนนักศึกษา

Asymmetric Encryption (ใช้กุญแจคู่)

ใช้กุญแจ 2 ชุด คือ กุญแจสาธารณะ (Public Key) และกุญแจส่วนตัว (Private Key) เหมาะสำหรับการแลกเปลี่ยนกุญแจและการยืนยันตัวตน



ตัวอย่างการใช้งาน

HTTPS/TLS
ใช้กุญแจคู่ในการแลกเปลี่ยนกุญแจสำหรับการเชื่อมต่อที่ปลอดภัย

การยืนยันตัวตน (Digital Signature)
เช่น ลายเซ็นดิจิทัลของเอกสารการลงทะเบียน

การส่งอีเมลที่ปลอดภัย (S/MIME)
ใช้กุญแจคู่ในการเข้ารหัสและยืนยันผู้ส่ง

วิธีการแลกเปลี่ยนกุญแจและการเก็บกุญแจ

การใช้งานการเข้ารหัสให้ปลอดภัย ไม่ได้มีแค่การเข้ารหัสข้อมูล แต่ต้องมีวิธีแลกเปลี่ยนกุญแจให้ปลอดภัย และเก็บกุญแจอย่างเหมาะสม เพื่อป้องกันการถูกขโมยกุญแจ หรือการเข้าถึงข้อมูลโดยไม่ได้รับอนุญาต

วิธีการแลกเปลี่ยนกุญแจ (Key Exchange)

ใช้สำหรับแลกเปลี่ยนกุญแจระหว่างผู้ส่งและผู้รับ เพื่อให้สามารถเข้ารหัสและถอดรหัสข้อมูลได้

1. ใช้การเข้ารหัสแบบอสมมาตร (Asymmetric) ในการแลกเปลี่ยนกุญแจ

ใช้ Public Key ของผู้รับในการเข้ารหัสกุญแจแบบสมมาตร (Session Key) แล้วส่งให้ผู้รับ



2. ใช้ Key Exchange Protocol (เช่น Diffie-Hellman) สร้างกุญแจร่วม

ทั้งสองฝ่ายร่วมกันสร้างกุญแจแบบสมมาตร โดยไม่ต้องส่งกุญแจผ่านเครือข่าย



การเก็บกุญแจ (Key Storage)

ควรเก็บกุญแจในที่ปลอดภัย และกำหนดสิทธิ์การเข้าถึงอย่างเหมาะสม

1. เก็บใน Cloud KMS (แนะนำ)

Cloud KMS
(Key Management Service)

- เก็บกุญแจในบริการที่ปลอดภัยของ Google Cloud
- กำหนดสิทธิ์การเข้าถึงด้วย IAM
- รองรับการหมุนเวียนกุญแจ (Key Rotation)
- ไม่ต้องดูแลโครงสร้างพื้นฐานเอง

2. เก็บใน Hardware Security Module (HSM)

HSM
Hardware Security Module

- เก็บกุญแจในอุปกรณ์เฉพาะทาง
- ป้องกันการเข้าถึงกุญแจโดยไม่ผ่านการยืนยันตัวตน
- เหมาะสำหรับองค์กรที่ต้องการความปลอดภัยสูง

3. เก็บในไฟล์ (ไม่แนะนำ)

Key File

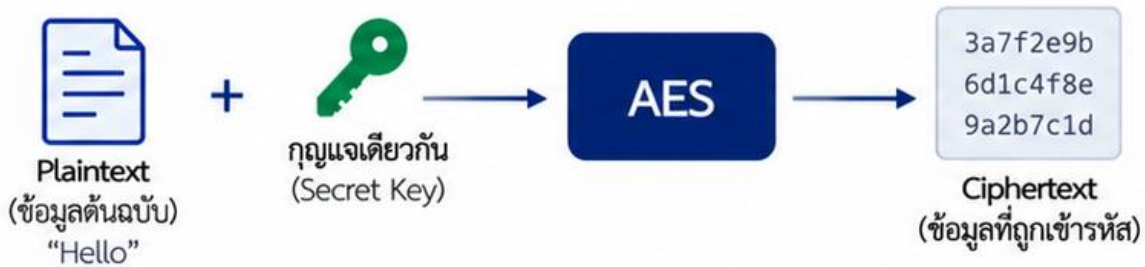
- เสี่ยงต่อการถูกขโมยกุญแจ
- ต้องจัดการการเข้าถึงและการสำรองข้อมูลเอง
- เหมาะสำหรับการใช้งานทดสอบเท่านั้น

หลักการทำงานของอัลกอริทึมการเข้ารหัสที่นิยมใช้

ตัวอย่างอัลกอริทึมที่นิยมใช้ในระบบจริง ได้แก่ AES และ RSA ซึ่งมีกลไกการทำงานที่แตกต่างกัน

AES (Advanced Encryption Standard)

อัลกอริทึมแบบ Symmetric ใช้กุญแจเดียวกันในการเข้ารหัสและถอดรหัส



หลักการทำงาน (แบบง่าย)

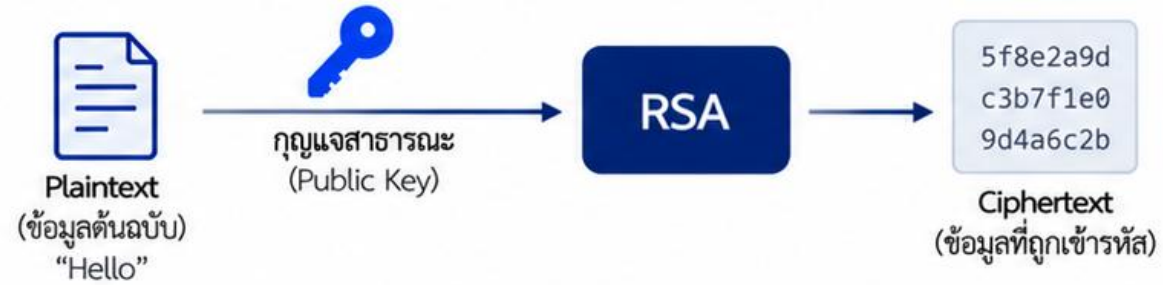


จุดเด่น



RSA (Rivest-Shamir-Adleman)

อัลกอริทึมแบบ Asymmetric ใช้กุญแจคู่ คือ กุญแจสาธารณะและกุญแจส่วนตัว



หลักการทำงาน (แบบง่าย)



จุดเด่น



Key Management & Cloud KMS

Key Management คืออะไร?

การสร้าง จัดเก็บ ใช้งาน หมุนเวียน และยกเลิกกุญแจอย่างปลอดภัยตลอดวงจรชีวิต

วงจรชีวิตของกุญแจ (Key Lifecycle)

1. สร้าง (Generate) → 2. จัดเก็บ (Store) → 3. ใช้งาน (Use) → 4. หมุนเวียน (Rotate) → 5. ยกเลิก (Revoke/Destroy)

วิธีการจัดเก็บกุญแจ

เก็บในแอปพลิเคชัน

- เสี่ยงต่อการรั่วไหล
- ดูแลยาก
- ไม่เหมาะสำหรับระบบจริง

เก็บในไฟล์

- ต้องป้องกันไฟล์อย่างดี
- ต้องจัดการสิทธิ์การเข้าถึง
- เสี่ยงหากไฟล์ถูกขโมย

เก็บใน Hardware (HSM) / Cloud KMS (แนะนำ)

HSM / KMS

- ปลอดภัยกว่าด้วยการป้องกันทางกายภาพ
- ควบคุมการเข้าถึงได้
- มีการบันทึกการใช้งาน (Audit Log)

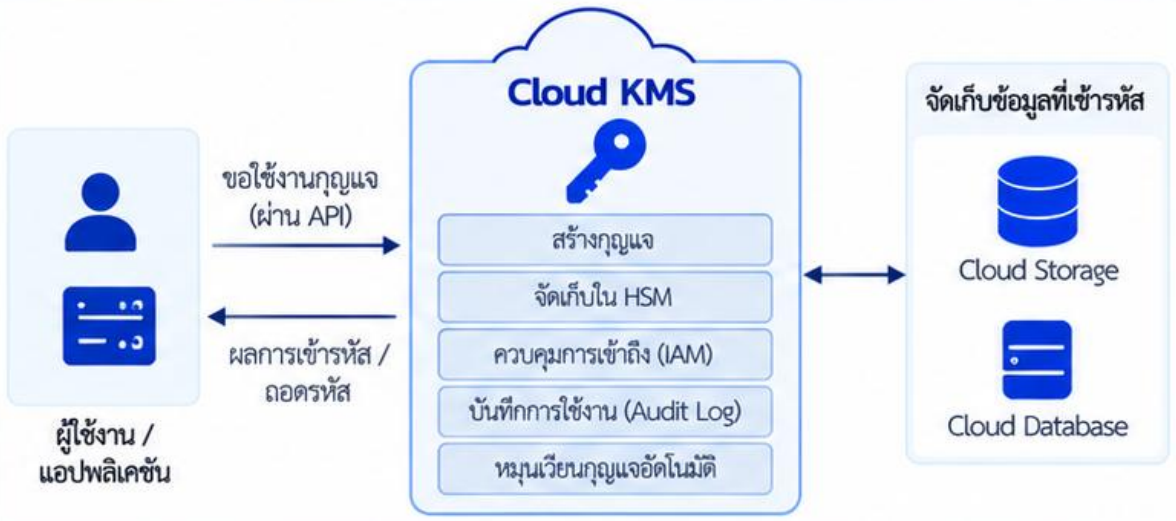
แนวทางปฏิบัติที่ดี

- **จำกัดสิทธิ์การเข้าถึง** ใช้หลัก Least Privilege
- **หมุนเวียนกุญแจสม่ำเสมอ** ลดความเสี่ยงหากรั่วไหล
- **มีการบันทึกการใช้งาน** เพื่อตรวจสอบย้อนหลัง
- **แยกหน้าที่ความรับผิดชอบ** เช่น ผู้ดูแลระบบ และผู้ใช้งาน

Cloud KMS คืออะไร?

บริการจัดการกุญแจบนคลาวด์ (Key Management Service) ช่วยให้สร้าง จัดเก็บ ใช้งาน และควบคุมการเข้าถึงกุญแจได้อย่างปลอดภัย โดยไม่ต้องดูแลโครงสร้างพื้นฐานเอง

ภาพรวมการใช้งาน Cloud KMS



ตัวอย่างบริการ Cloud KMS

Google Cloud KMS

- จัดเก็บกุญแจใน HSM ของ Google
- ควบคุมการเข้าถึงด้วย IAM
- รองรับการหมุนเวียนกุญแจ

AWS KMS

- จัดเก็บกุญแจใน HSM
- ผสานกับ IAM
- รองรับการเข้ารหัสหลายบริการ (S3, RDS ฯลฯ)

Azure Key Vault

- จัดเก็บกุญแจและความลับ
- ควบคุมการเข้าถึงด้วย RBAC
- รองรับการหมุนเวียนกุญแจ และการบันทึกการใช้งาน

HSM: Hardware Security Module

Digital Certificate & Public Key Infrastructure (PKI)

Digital Certificate ใช้ยืนยันตัวตนของผู้ใช้/เซิร์ฟเวอร์ โดยผูก “กุญแจสาธารณะ” กับ “ข้อมูลตัวตน” ผ่านลายเซ็นดิจิทัลของหน่วยงานที่เชื่อถือได้ (Certificate Authority: CA)

Digital Certificate คืออะไร?

ไฟล์ข้อมูลที่ระบุว่ากุญแจสาธารณะนี้เป็นของใคร และออกโดยใคร

Certificate



Subject : www.example.com
Public Key : 04:a3:5f:...
Issuer : Example CA
Valid From : 2024-01-01
Valid To : 2025-01-01
Signature : (ลายเซ็นของ CA)

- ข้อมูลตัวตนของเจ้าของ
- กุญแจสาธารณะ
- ข้อมูลการใช้งาน
- ลายเซ็นดิจิทัลของ CA ป้องกันการปลอมแปลง

โครงสร้างของ PKI (Public Key Infrastructure)

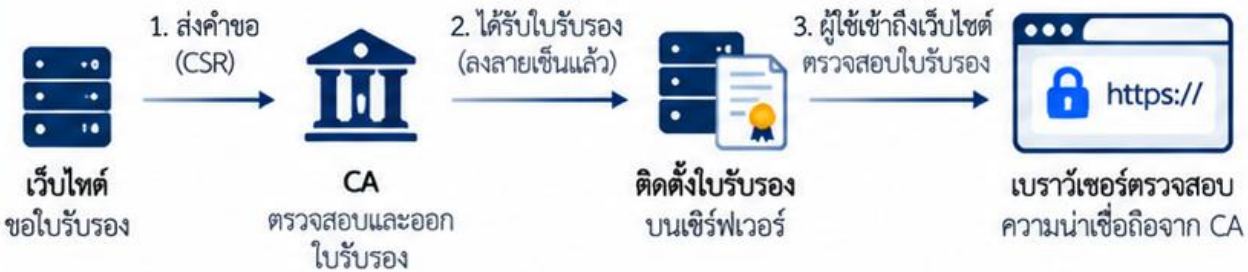
PKI คือระบบที่ใช้จัดการการออก การใช้งาน และการตรวจสอบ Digital Certificate



องค์ประกอบอื่น ๆ ใน PKI

- **Registration Authority (RA)**
  ตรวจสอบตัวตนก่อนออกใบรับรอง
- **Certificate Revocation List (CRL)**
  รายการใบรับรองที่ถูกเพิกถอน
- **Online Certificate Status Protocol (OCSP)**
  ตรวจสอบสถานะใบรับรองแบบเรียลไทม์

ขั้นตอนการออกและใช้งานใบรับรอง (ตัวอย่าง: เว็บไซต์ HTTPS)



ประโยชน์ของ Digital Certificate / PKI

ยืนยันตัวตน
มั่นใจว่าเชื่อมต่อกับเจ้าของที่ถูกต้อง

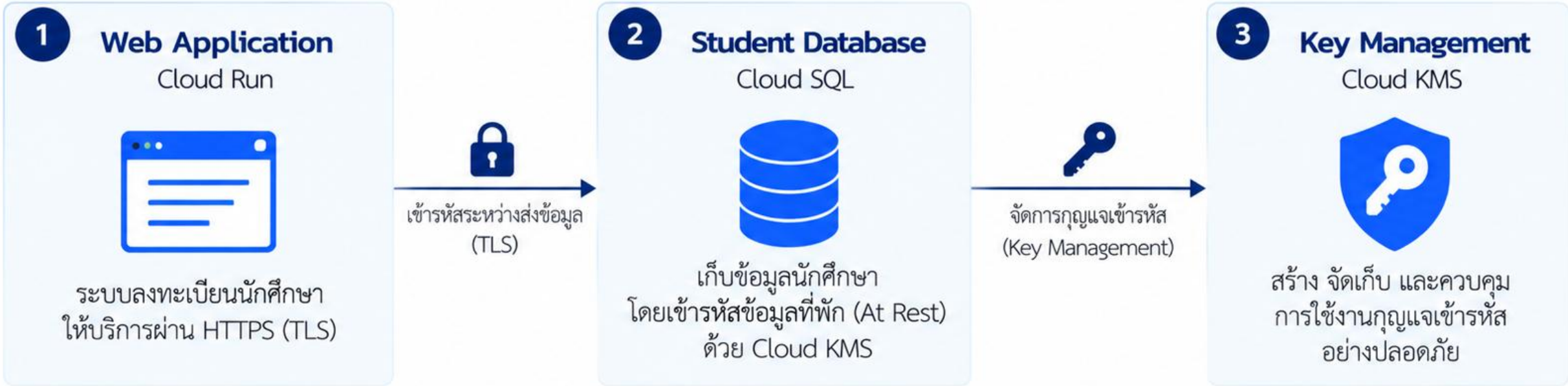
เข้ารหัสข้อมูล
ใช้กุญแจสาธารณะเพื่อเข้ารหัส (เช่น TLS)

ป้องกันการปลอมแปลง
ลายเซ็นดิจิทัลของ CA ช่วยตรวจสอบความถูกต้อง

สร้างความน่าเชื่อถือ
อาศัย CA ที่เป็นที่ยอมรับในวงกว้าง

Data Security Architecture Design (Student Registration on GCP)

ออกแบบสถาปัตยกรรมการปกป้องข้อมูลนักศึกษา โดยใช้บริการหลักบน Google Cloud Platform



1 เข้ารหัสระหว่างส่งข้อมูล (In Transit)

- ผู้ใช้เข้าถึงระบบผ่าน HTTPS (TLS)
- ข้อมูลถูกเข้ารหัสระหว่างส่งจากผู้ใช้ไปยัง Cloud Run และ Cloud SQL
- ป้องกันการดักฟังและการแก้ไขข้อมูลระหว่างทาง

2 เข้ารหัสข้อมูลที่พัก (At Rest)

- ข้อมูลนักศึกษาถูกเก็บใน Cloud SQL
- ใช้ Cloud KMS จัดการกุญแจเข้ารหัส
- หากฐานข้อมูลถูกขโมย ข้อมูลยังไม่สามารถอ่านได้โดยไม่มีกุญแจ

3 จัดการกุญแจเข้ารหัสด้วย Cloud KMS

- สร้างและเก็บกุญแจเข้ารหัสใน Cloud KMS
- ควบคุมสิทธิ์การใช้งานกุญแจด้วย IAM
- ระบบและผู้ใช้ไม่ต้องเห็นกุญแจโดยตรง
- ช่วยให้การหมุนเวียน (Rotate) และเพิกถอนกุญแจทำได้อย่างปลอดภัย

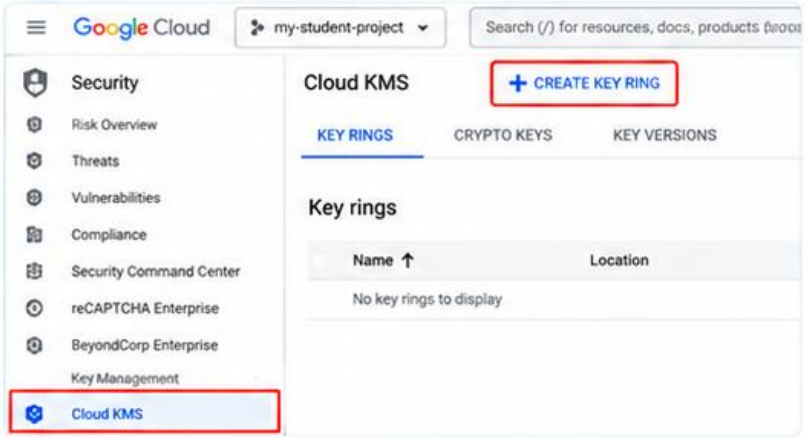
Data Security Setup on GCP (ตัวอย่างหน้าจอ)

ตัวอย่างการตั้งค่าบริการบน Google Cloud Platform เพื่อปกป้องข้อมูลนักศึกษา

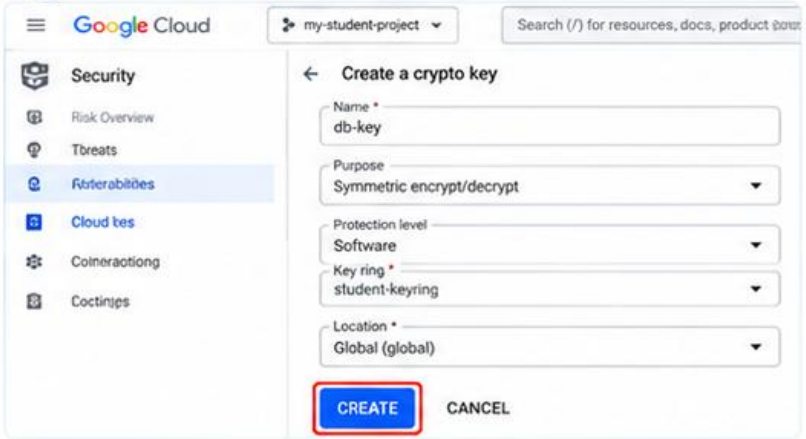
1 สร้างและตั้งค่า Cloud KMS

สร้าง Key ring และ Crypto key สำหรับเข้ารหัสข้อมูล

1.1 สร้าง Key ring

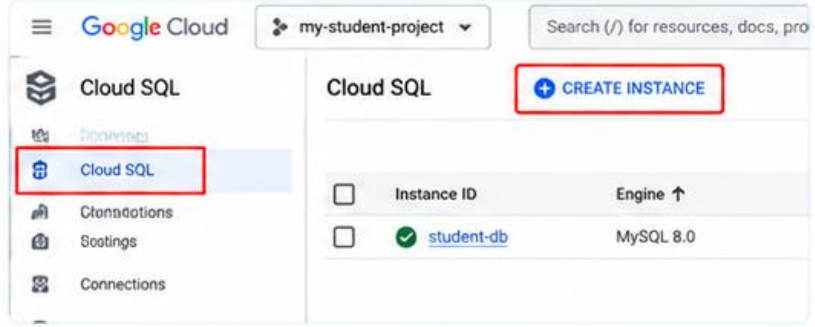


1.2 สร้าง Crypto key ใน Key ring ที่สร้างไว้

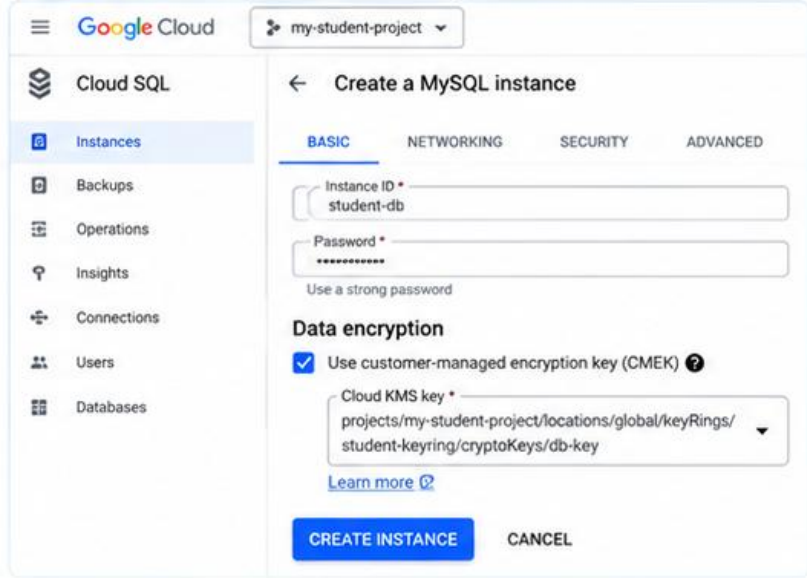


2 ตั้งค่า Cloud SQL ให้เข้ารหัสด้วย CMEK

สร้างฐานข้อมูลและเลือกใช้กุญแจเข้ารหัสจาก Cloud KMS

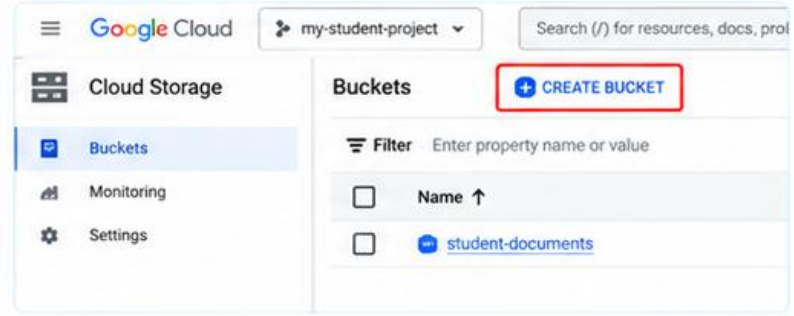


2.1 เลือก Cloud KMS key สำหรับเข้ารหัสข้อมูล

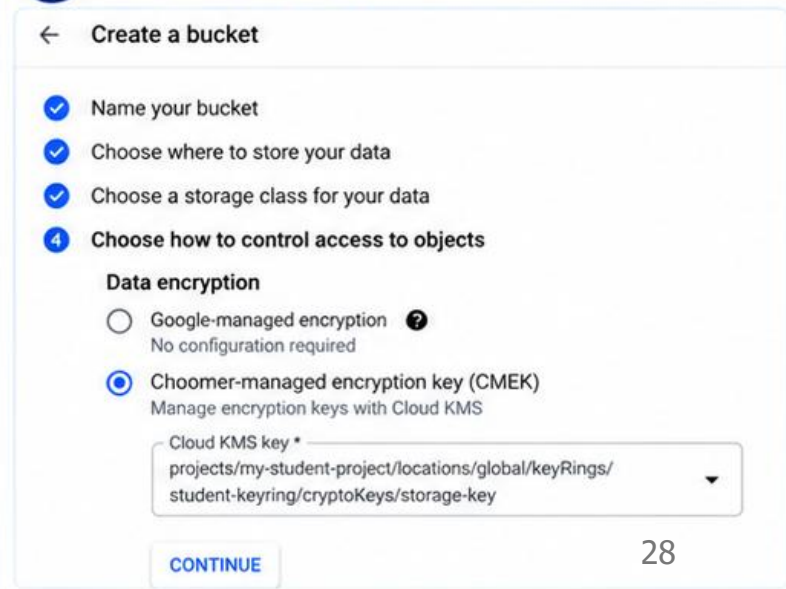


3 ตั้งค่า Cloud Storage ให้เข้ารหัสด้วย CMEK

สร้าง Bucket สำหรับเก็บเอกสารนักศึกษาและเลือกใช้กุญแจจาก Cloud KMS



3.1 เลือก Cloud KMS key สำหรับเข้ารหัสไฟล์



Monitoring & Incident Response

Monitoring & Incident Response

การติดตามเหตุการณ์ด้านความปลอดภัย ตรวจจับความผิดปกติ และตอบสนองต่อเหตุการณ์อย่างรวดเร็ว เพื่อลดความเสี่ยงและผลกระทบต่อข้อมูล

1 Monitoring บน Google Cloud

ใช้บริการของ Google Cloud เพื่อติดตามกิจกรรมและตรวจจับเหตุการณ์ที่อาจเป็นภัยคุกคาม

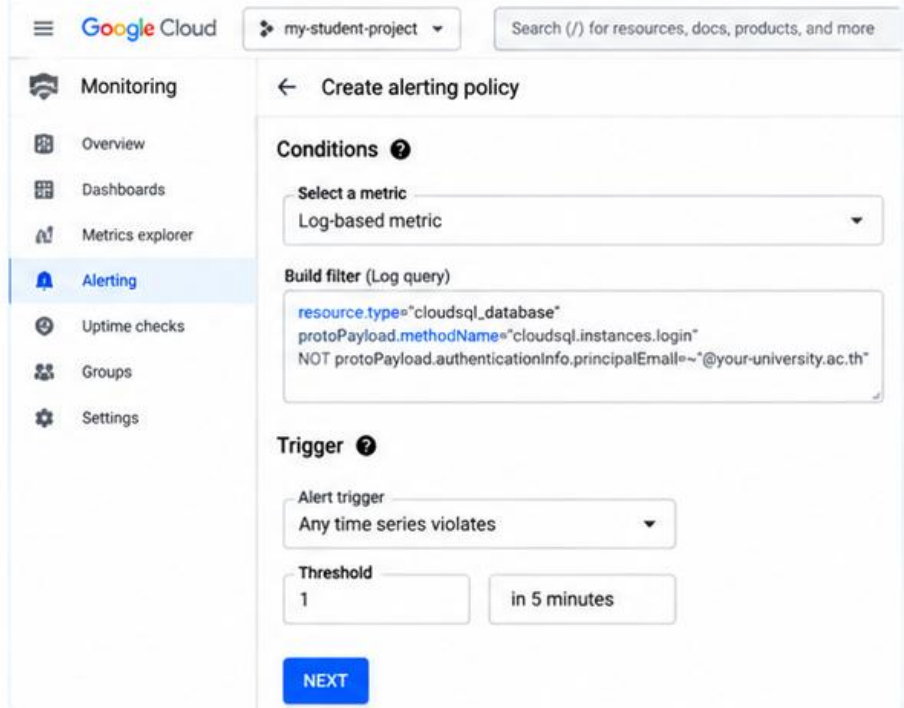
Cloud Logging
เก็บบันทึกกิจกรรม (Logs)
เช่น การเข้าถึง การเปลี่ยนแปลงการตั้งค่า

Cloud Monitoring
ติดตามสถานะระบบและประสิทธิภาพ
พร้อมแจ้งเตือนเมื่อมีความผิดปกติ

Security Command Center
ตรวจจับภัยคุกคามและความเสี่ยงด้านความปลอดภัย
พร้อมคำแนะนำในการแก้ไข

2 ตัวอย่างการตรวจจับและแจ้งเตือน

ตั้งค่า Alert เมื่อพบพฤติกรรมที่ผิดปกติ เช่น การเข้าสู่ระบบจากประเทศที่ไม่เคยใช้งาน หรือความพยายามเข้าถึงข้อมูลผิดปกติ



3 Incident Response Process

เมื่อเกิดเหตุการณ์ด้านความปลอดภัย ให้ตอบสนองอย่างเป็นระบบ เพื่อลดผลกระทบและป้องกันการเกิดซ้ำ

1. **ตรวจจับ (Detect)**
   รับแจ้งเตือนจาก Monitoring / Security Command Center
2. **วิเคราะห์ (Analyze)**
   ตรวจสอบรายละเอียดจาก Logs และประเมินผลกระทบ
3. **ตอบสนอง (Respond)**
   ดำเนินการแก้ไข เช่น ปิดบัญชีผู้ใช้ บล็อกการเข้าถึง
4. **ฟื้นฟู (Recover)**
   กู้คืนระบบและตรวจสอบความถูกต้องของข้อมูล
5. **ป้องกันการเกิดซ้ำ (Lessons Learned)**
   ทบทวนสาเหตุและปรับปรุงมาตรการรักษาความปลอดภัย

4 ประโยชน์ของ Monitoring & Incident Response

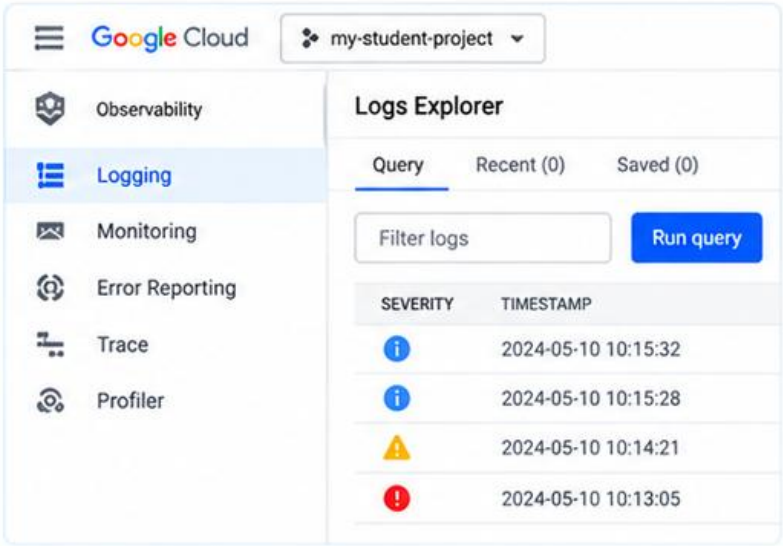
- **ตรวจจับภัยคุกคามได้เร็ว**
  ลดความเสียหายที่อาจเกิดขึ้นกับข้อมูลนักศึกษา
- **ตอบสนองได้ทันเวลา**
  ลดระยะเวลาที่ระบบถูกโจมตีหรือถูกเข้าถึงโดยไม่ได้รับอนุญาต
- **มีหลักฐานสำหรับการตรวจสอบ**
  ใช้ Logs เพื่อวิเคราะห์เหตุการณ์และรองรับการตรวจสอบตามข้อกำหนด
- **เพิ่มความเชื่อมั่นให้กับผู้ใช้งาน**
  ระบบมีการเฝ้าระวังและจัดการเหตุการณ์อย่างมืออาชีพ

Monitoring Setup on GCP (Student Registration)

ตัวอย่างการตั้งค่าการติดตามระบบลงทะเบียนนักศึกษา ด้วยบริการบน Google Cloud

1 เปิดใช้งาน Cloud Logging

เก็บบันทึกเหตุการณ์ (Logs) จากบริการต่าง ๆ
ในระบบลงทะเบียนนักศึกษา



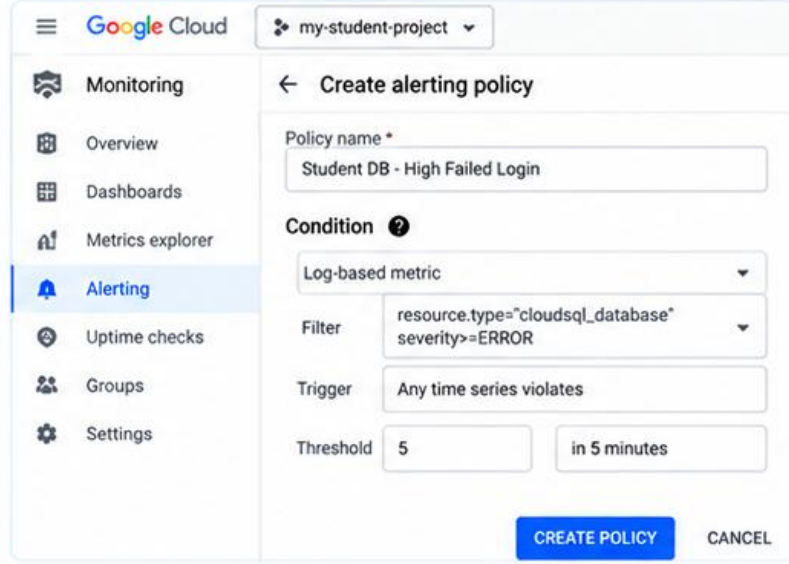
ตัวอย่างข้อมูลที่เก็บ

- การเข้าถึง Web Application
- การใช้งานฐานข้อมูล (Cloud SQL)
- การเปลี่ยนแปลงสิทธิ์ (IAM)
- เหตุการณ์ด้านความปลอดภัย

ประโยชน์
ช่วยให้ตรวจสอบเหตุการณ์ย้อนหลังได้
เมื่อเกิดปัญหาหรือเหตุการณ์ผิดปกติ

2 ตั้งค่า Alerting

แจ้งเตือนเมื่อเกิดเหตุการณ์ผิดปกติที่สำคัญ
เช่น มีการเข้าถึงข้อมูลผิดปกติ หรือระบบล่ม



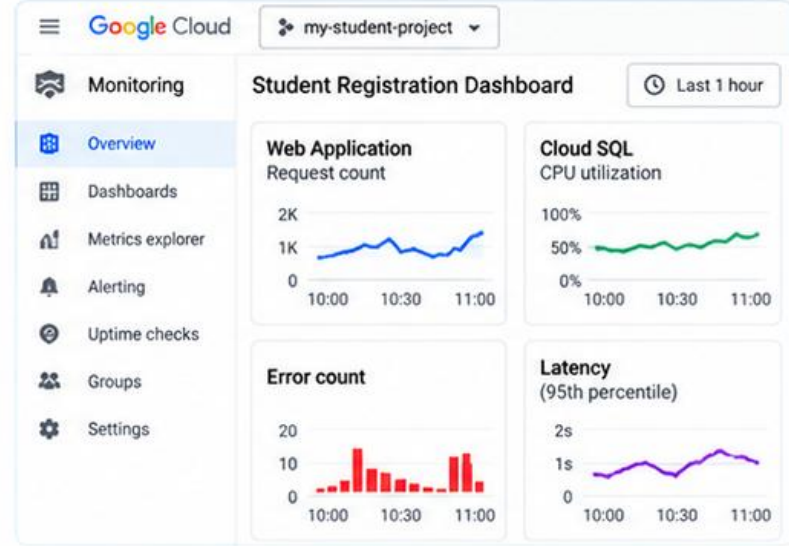
ตัวอย่างเหตุการณ์ที่แจ้งเตือน

- มีความพยายามเข้าสู่ระบบล้มเหลวจำนวนมาก
- มีการเข้าถึงฐานข้อมูลจาก IP ที่ไม่เคยใช้งาน
- บริการสำคัญ เช่น Web Application ไม่สามารถใช้งานได้

ประโยชน์
ช่วยให้ตรวจพบปัญหาได้รวดเร็ว
และลดความเสียหายที่อาจเกิดขึ้น

3 ดูข้อมูลผ่าน Dashboard

แสดงภาพรวมสถานะระบบแบบเรียลไทม์
เพื่อให้ติดตามได้ง่าย



ตัวอย่างข้อมูลใน Dashboard

- จำนวนคำขอใช้งานระบบ (Request count)
- การใช้งาน CPU ของฐานข้อมูล (Cloud SQL)
- จำนวนข้อผิดพลาด (Error count)
- เวลาตอบสนองของระบบ (Latency)

ประโยชน์
ช่วยให้เห็นสถานะระบบแบบภาพรวม
และติดตามแนวโน้มของปัญหาได้ง่าย

Incident Response Process (Student Registration)

ขั้นตอนการรับมือเมื่อเกิดเหตุการณ์ด้านความปลอดภัย เพื่อลดผลกระทบและป้องกันไม่ให้เกิดขึ้นอีก

1 ตรวจจับ (Detect)



ตรวจพบเหตุการณ์ผิดปกติ
จากการแจ้งเตือนหรือ Logs

2 วิเคราะห์ (Analyze)



ตรวจสอบรายละเอียด
ประเมินผลกระทบ
และยืนยันว่าเป็นเหตุการณ์จริง

3 ตอบสนอง (Respond)



ดำเนินการแก้ไข
เช่น ปิดการเข้าถึง
หรือเปลี่ยนสิทธิ์การใช้งาน

4 ฟื้นฟู (Recover)



กู้คืนระบบและข้อมูล
ให้กลับมาใช้งานได้
อย่างปลอดภัย

5 ป้องกันในอนาคต (Lessons Learned)



ทบทวนสาเหตุ
และปรับปรุงมาตรการ
เพื่อป้องกันไม่ให้เกิดขึ้นอีก

ตัวอย่างเหตุการณ์ที่ตรวจพบ

- มีการพยายามเข้าสู่ระบบหลายครั้ง (Failed login)
- มีการเข้าถึงข้อมูลที่ไม่เคยใช้
- ปริมาณการใช้งานเพิ่มขึ้นผิดปกติ

ตัวอย่างการวิเคราะห์

- ตรวจสอบจาก Logs ว่าเป็นการเข้าถึงจาก IP ใด
- ตรวจสอบว่ามีข้อมูลถูกเข้าถึงหรือไม่
- ประเมินว่ากระทบต่อข้อมูลนักศึกษาหรือไม่

ตัวอย่างการตอบสนอง

- ปิดบัญชีผู้ใช้ที่น่าสงสัย
- เปลี่ยนรหัสผ่าน
- ปรับสิทธิ์การเข้าถึง (IAM)
- บล็อก IP ที่เป็นอันตรายผ่าน Firewall

ตัวอย่างการฟื้นฟู

- กู้คืนข้อมูลจาก Backup หากมีการเปลี่ยนแปลงข้อมูล
- ตรวจสอบความถูกต้องของข้อมูล
- เปิดให้บริการระบบอีกครั้งหลังยืนยันว่าปลอดภัย

ตัวอย่างสิ่งที่ได้เรียนรู้

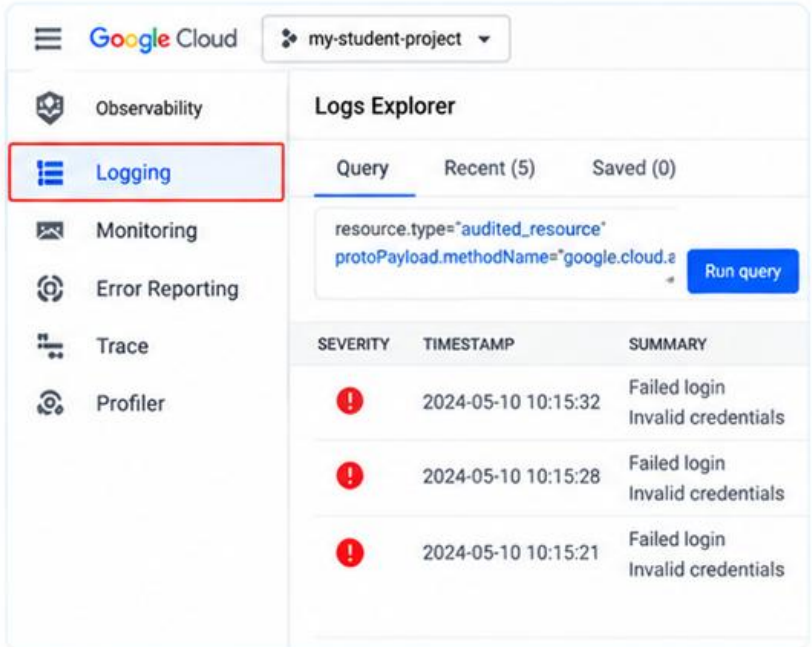
- ปรับปรุงกฎการแจ้งเตือนให้ครอบคลุมมากขึ้น
- เพิ่มการตรวจสอบสิทธิ์อย่างสม่ำเสมอ
- จัดทำแนวทางปฏิบัติและอบรมผู้ใช้งาน

Incident Response Example on GCP (Student Registration)

ตัวอย่างการตรวจพบ วิเคราะห์ และตอบสนองเหตุการณ์การเข้าถึงข้อมูลโดยไม่ได้รับอนุญาต

1 ตรวจพบเหตุการณ์จาก Logging

พบความพยายามเข้าสู่ระบบล้มเหลวหลายครั้ง
จาก IP ที่ไม่เคยใช้งาน

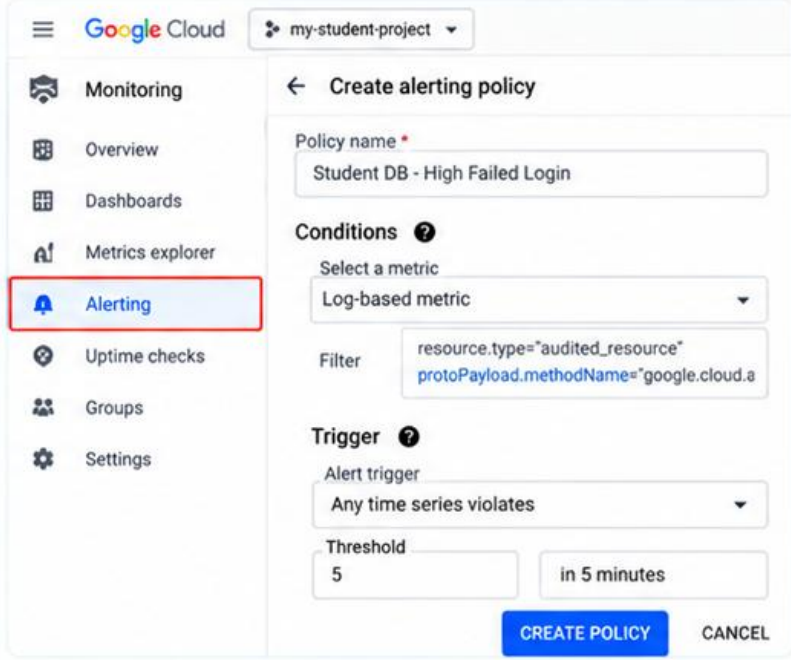


สิ่งที่ตรวจพบ

- มีการพยายามเข้าสู่ระบบหลายครั้ง (Failed login)
- มาจาก IP address ที่ไม่เคยใช้งานมาก่อน
- อาจเป็นการพยายามเข้าถึงระบบโดยไม่ได้รับอนุญาต

2 วิเคราะห์ด้วย Alerting

ตั้งค่าแจ้งเตือนเมื่อมีการเข้าสู่ระบบล้มเหลว
เกินจำนวนที่กำหนด

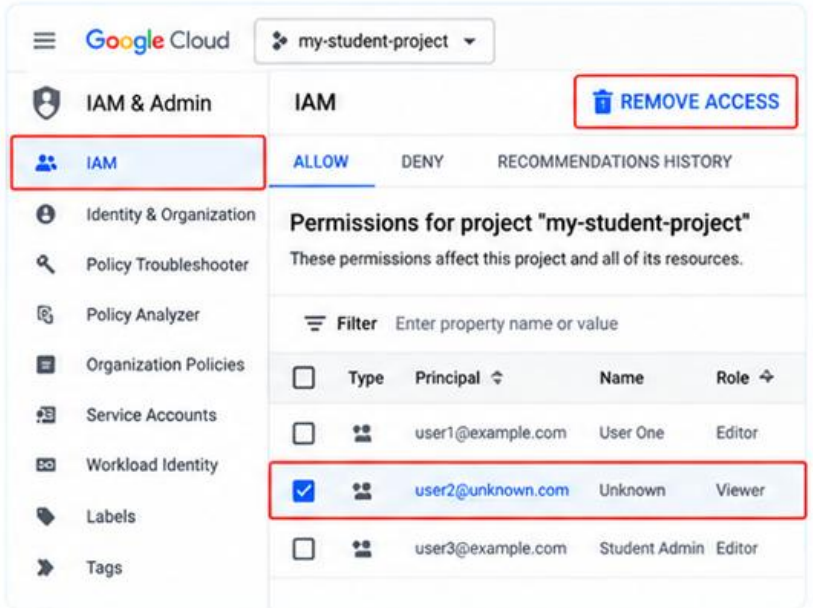


การตั้งค่าแจ้งเตือน

- ใช้ Log-based metric จาก Cloud Logging
- แจ้งเตือนเมื่อมีการเข้าสู่ระบบล้มเหลวมากกว่า 5 ครั้ง ภายใน 5 นาที
- ส่งการแจ้งเตือนไปยังอีเมลของผู้ดูแลระบบ

3 ตอบสนองเหตุการณ์

เมื่อได้รับการแจ้งเตือน ให้ดำเนินการแก้ไขทันที
เพื่อลดความเสี่ยง



การตอบสนองที่ควรทำ

- ตรวจสอบบัญชีผู้ใช้ที่เกี่ยวข้อง
- บล็อกหรือปิดสิทธิ์บัญชีที่น่าสงสัย
- ตรวจสอบว่ามีข้อมูลถูกเข้าถึงหรือไม่
- ติดตามเหตุการณ์เพิ่มเติม และปรับปรุงมาตรการป้องกัน เช่น ใช้การยืนยันตัวตนแบบ 2 ขั้นตอน (2FA)

Cloud Migrations

Cloud Migration Strategies (7 Rs)

แนวทางการย้ายระบบขึ้นคลาวด์ที่นิยมใช้ 7 รูปแบบ ช่วยให้องค์กรเลือกวิธีที่เหมาะสมกับความต้องการ งบประมาณ และความเสี่ยง

1 

Rehost (Lift and Shift)
ย้ายระบบขึ้นคลาวด์โดยแทบไม่ต้องเปลี่ยนแปลง

- ย้ายเครื่องเซิร์ฟเวอร์เดิมไปยัง Compute Engine
- ทำได้เร็ว ค่าใช้จ่ายเริ่มต้นต่ำ
- **ตัวอย่าง**: ย้ายระบบลงทะเบียนนักศึกษาเดิมไปยัง VM บน Google Cloud

2 

Replatform
ปรับเปลี่ยนบางส่วนเพื่อให้เหมาะกับคลาวด์มากขึ้น

- ปรับปรุงให้ใช้บริการของคลาวด์ เช่น ฐานข้อมูลแบบ Managed Service
- ช่วยลดภาระการดูแลรักษา
- ตัวอย่าง: ย้ายฐานข้อมูลไปยัง Cloud SQL

3 

Refactor (Re-architect)
ปรับปรุงสถาปัตยกรรมใหม่ให้เป็นแบบ Cloud-native

- ออกแบบระบบใหม่ เช่น ใช้ Microservices, Containers
- เหมาะกับระบบที่ต้องการความยืดหยุ่นและขยายตัวได้ดี
- **ตัวอย่าง**: ปรับระบบลงทะเบียนเป็น Microservices บน GKE

4 

Repurchase
เปลี่ยนไปใช้บริการซอฟต์แวร์สำเร็จรูปบนคลาวด์ (SaaS)

- ใช้ซอฟต์แวร์ที่ให้บริการแบบ SaaS แทนการดูแลเอง
- ลดภาระการดูแลระบบ
- **ตัวอย่าง**: ใช้ Google Workspace แทนระบบอีเมลและเอกสารภายใน

5 

Retire
ยกเลิกระบบที่ไม่จำเป็นเพื่อลดค่าใช้จ่าย

- ยกเลิกแอปพลิเคชันหรือระบบที่ไม่ได้ใช้งานแล้ว
- ช่วยลดค่าใช้จ่ายและลดความเสี่ยงด้านความปลอดภัย
- **ตัวอย่าง**: ยกเลิกระบบรายงานเก่าที่ไม่มีผู้ใช้งาน

6 

Retain
คงระบบไว้ที่เดิมชั่วคราว ยังไม่ย้ายขึ้นคลาวด์

- เก็บระบบไว้ในศูนย์ข้อมูลเดิมก่อน
- ใช้ในกรณีที่ยังมีข้อจำกัด เช่น กฎหมาย หรือความพร้อมของระบบ
- ตัวอย่าง: เก็บระบบบางส่วนที่มีข้อจำกัดในการย้าย

7 

Relocate
ปรับไปยังสภาพแวดล้อมคลาวด์อื่น

- ย้ายระบบจากผู้ให้บริการคลาวด์อื่นมาที่ Google Cloud
- ใช้เมื่อต้องการมาตรฐาน บริการ หรือค่าใช้จ่ายที่เหมาะสมกว่า
- **ตัวอย่าง**: ย้ายระบบจากคลาวด์อื่นมาใช้ Google Cloud

Cloud Migration Process

ขั้นตอนการย้ายระบบขึ้นคลาวด์ ตั้งแต่การวางแผนจนถึงการใช้งานและปรับปรุงอย่างต่อเนื่อง

1 Assess



- สำรวจระบบและสินทรัพย์ที่มีอยู่
- ประเมินความพร้อมด้านเทคโนโลยี ทีมงาน และงบประมาณ
- ระบุความต้องการทางธุรกิจและความเสี่ยง

2 Plan



- กำหนดเป้าหมายและขอบเขตการย้ายระบบ
- เลือกกลยุทธ์การย้าย (7 Rs) ที่เหมาะสม
- จัดทำแผนงาน ระยะเวลา ทรัพยากร และผู้รับผิดชอบ

3 Migrate



- ดำเนินการย้ายระบบตามแผนที่กำหนด
- ใช้เครื่องมือของผู้ให้บริการคลาวด์ (เช่น Migrate to Compute Engine)
- ทดสอบการทำงานของระบบหลังการย้าย

4 Validate



- ตรวจสอบว่าระบบทำงานได้ถูกต้องครบถ้วน
- ทดสอบประสิทธิภาพ ความปลอดภัย และการเชื่อมต่อ
- ยืนยันว่าเป็นไปตามข้อกำหนดทางธุรกิจและมาตรฐานที่เกี่ยวข้อง

5 Optimize



- ปรับปรุงประสิทธิภาพและลดค่าใช้จ่าย
- ใช้บริการคลาวด์ให้เหมาะสมกับงาน เช่น Managed Service
- ติดตามการใช้งานอย่างต่อเนื่องและปรับปรุงตามความต้องการขององค์กร

ปัจจัยสำคัญสู่ความสำเร็จ

- การสนับสนุนจากผู้บริหาร
- การวางแผนที่ชัดเจน
- การเลือกกลยุทธ์ที่เหมาะสม
- การบริหารความเสี่ยงและความปลอดภัย
- การสื่อสารและการมีส่วนร่วมของทีมงาน
- การติดตามและปรับปรุงอย่างต่อเนื่อง

Migration Planning Considerations

ปัจจัยสำคัญที่ต้องพิจารณาในการวางแผนการย้ายระบบขึ้นคลาวด์ เพื่อให้การย้ายระบบประสบความสำเร็จ

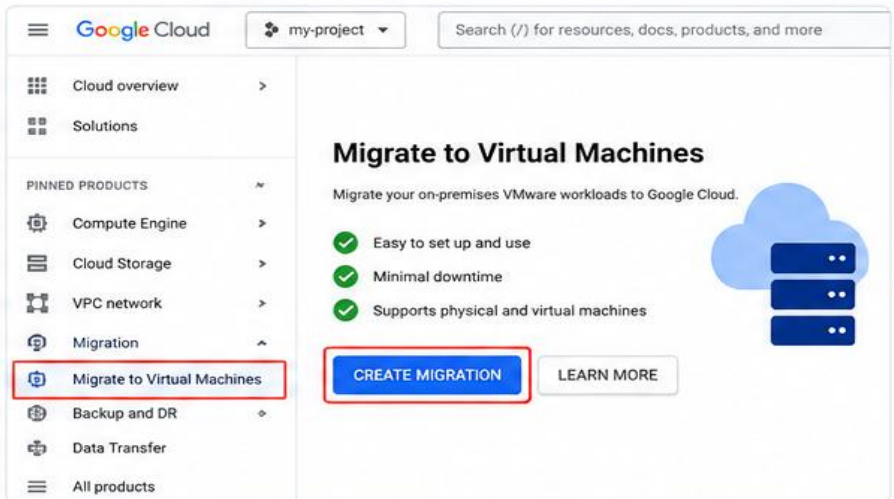
1	**Business Objectives** เป้าหมายทางธุรกิจ	• กำหนดเป้าหมายที่ชัดเจน เช่น ลดค่าใช้จ่าย เพิ่มความยืดหยุ่น หรือปรับปรุงประสิทธิภาพ • เชื่อมโยงการย้ายระบบกับกลยุทธ์ขององค์กร • กำหนดตัวชี้วัดความสำเร็จ (KPIs)
2	**Application Portfolio** ระบบงานและแอปพลิเคชัน	• ประเมินระบบงานที่มีอยู่ทั้งหมด • จัดกลุ่มความสำคัญและความเหมาะสมในการย้าย (7 Rs) • ระบุความสัมพันธ์ระหว่างระบบ (Dependencies)
3	**Infrastructure & Platform** โครงสร้างพื้นฐานและแพลตฟอร์ม	• เลือกบริการคลาวด์ที่เหมาะสม (Compute, Storage, Database, Network) • พิจารณาความเข้ากันได้ของเทคโนโลยี • ออกแบบสถาปัตยกรรมเป้าหมายบนคลาวด์
4	**Security & Compliance** ความปลอดภัยและการปฏิบัติตามข้อกำหนด	• ประเมินความเสี่ยงด้านความปลอดภัย • กำหนดมาตรการป้องกันข้อมูลและการเข้าถึง • พิจารณาข้อกำหนดด้านกฎหมาย เช่น PDPA, ISO 27001
5	**Cost & Budget** ค่าใช้จ่ายและงบประมาณ	• ประเมินค่าใช้จ่ายทั้งหมด (TCO) • เปรียบเทียบรูปแบบการคิดค่าใช้จ่ายของบริการคลาวด์ • วางแผนงบประมาณระยะสั้นและระยะยาว
6	**People & Skills** บุคลากรและทักษะ	• ประเมินทักษะของทีมงานที่มีอยู่ • วางแผนการฝึกอบรมและพัฒนาทักษะ • กำหนดบทบาทและความรับผิดชอบในโครงการย้ายระบบ
7	**Timeline & Risk Management** ระยะเวลาและการจัดการความเสี่ยง	• กำหนดแผนงานและช่วงเวลาการย้ายระบบ • ระบุความเสี่ยงที่อาจเกิดขึ้นและแผนรองรับ • กำหนดแนวทางการทดสอบและการย้อนกลับ (Rollback Plan)

Example: Migrate to Virtual Machines on GCP

ตัวอย่างหน้าจอการใช้งาน Migrate to Virtual Machines สำหรับย้ายเซิร์ฟเวอร์ระบบลงทะเบียนนักศึกษาไปยัง Google Cloud

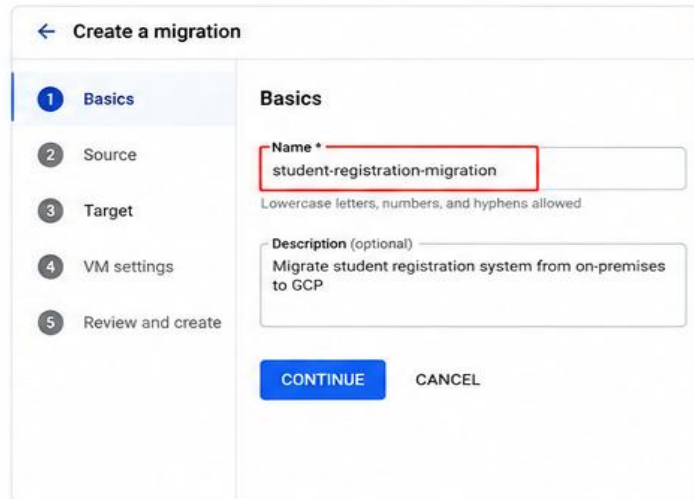
1 เปิดบริการ Migrate to Virtual Machines

ไปที่เมนู Migration > Migrate to Virtual Machines



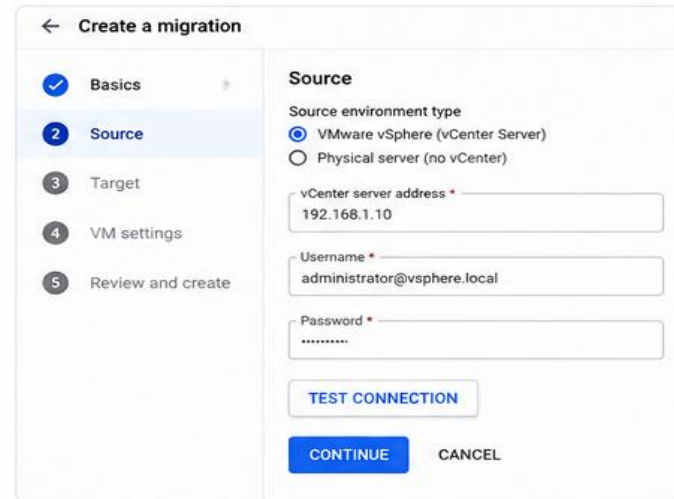
2 สร้าง Migration

คลิก Create migration และตั้งชื่อ



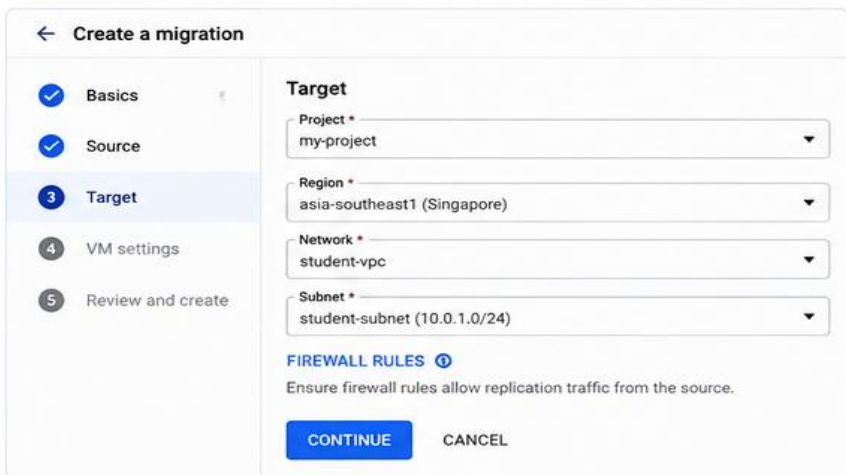
3 ตั้งค่า Source (เซิร์ฟเวอร์ต้นทาง)

เลือกประเภทแหล่งที่มาและระบุ vCenter หรือ Physical server



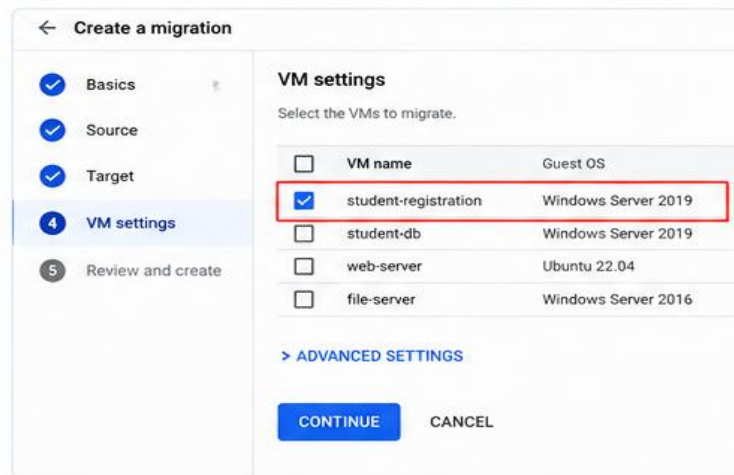
4 ตั้งค่า Target (ปลายทางบน GCP)

เลือก Project, Region, VPC และ Network



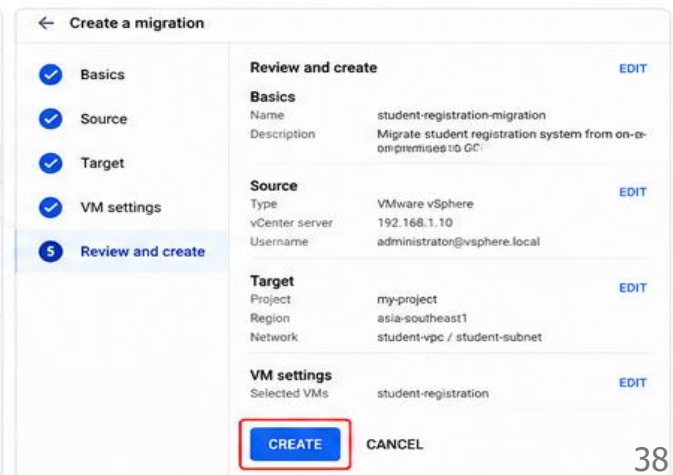
5 เลือก VM ที่ต้องการย้าย

เลือกเซิร์ฟเวอร์ระบบลงทะเบียนนักศึกษา



6 ตรวจสอบและเริ่มการย้าย

ตรวจสอบการตั้งค่าทั้งหมดและคลิก Create



Any Questions ?

